



Exam SY0-701

CompTIA Security+ Exam 2025

Version: 19.0

[Total Questions: 642]



1. SIMULATION

After multiple phishing simulations, the Chief Security Officer announces a new program that incentivizes employees to not click phishing links in the upcoming quarter. Which of the following security awareness execution techniques does this represent?

- A. Computer-based training
- B. Insider threat awareness
- C. SOAR playbook
- D. Gamification

Answer: D

Explanation:

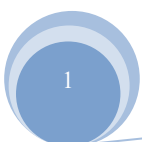
Gamification refers to the use of game elements such as points, rewards, competitions, and incentives to motivate users and enhance engagement in activities such as security awareness training. Incentivizing employees to avoid clicking phishing links by rewarding positive behavior is a classic example of gamification.

Computer-based training (A) is traditional online training without game elements. Insider threat awareness (B) focuses on educating about internal threats. SOAR playbook (C) refers to automated incident response workflows, unrelated to employee training methods. Gamification is recognized in the Security Program Management domain as an effective technique to improve user engagement and security behavior7:Chapter 5†CompTIA Security+ Practice Tests.

2. An employee fell for a phishing scam, which allowed an attacker to gain access to a company PC. The attacker scraped the PC's memory to find other credentials. Without cracking these credentials, the attacker used them to move laterally through the corporate network. Which of the following describes this type of attack?

- A. Privilege escalation
- B. Buffer overflow
- C. SQL injection
- D. Pass-the-hash

Answer: D





3. Which of the following security principles most likely requires validation before allowing traffic between systems?

- A. Policy enforcement
- B. Authentication
- C. Zero Trust architecture
- D. Confidentiality

Answer: C

4. A security analyst identifies an incident in the network. Which of the following incident response activities would the security analyst perform next?

- A. Containment
- B. Detection
- C. Eradication
- D. Recovery

Answer: A

5. A security analyst has determined that a security breach would have a financial impact of \$15,000 and is expected to occur twice within a three-year period. Which of the following is the ALE for this risk?

- A. \$7,500
- B. \$10,000
- C. \$15,000
- D. \$30,000

Answer: B

6. During an investigation, an incident response team attempts to understand the source of an incident. Which of the following incident response activities describes this process?

- A. Analysis
- B. Lessons learned
- C. Detection
- D. Containment



Answer: A

7. A group of developers has a shared backup account to access the source code repository. Which of the following is the best way to secure the backup account if there is an SSO failure?

- A. RAS
- B. EAP
- C. SAML
- D. PAM

Answer: D

8. An organization disabled unneeded services and placed a firewall in front of a business- critical legacy system. Which of the following best describes the actions taken by the organization?

- A. Exception
- B. Segmentation
- C. Risk transfer
- D. Compensating controls

Answer: D

9. Which of the following types of vulnerabilities involves attacking a system to access adjacent hosts?

- A. VM escape
- B. Side loading
- C. Remote code execution
- D. Resource exhaustion

Answer: A

10. Which of the following topics would most likely be included within an organization's SDLC?

- A. Service-level agreements
- B. Information security policy
- C. Penetration testing methodology
- D. Branch protection requirements



Answer: B

11. A security analyst is prioritizing vulnerability scan results using a risk-based approach. Which of the following is the most efficient resource for the analyst to use?

- A. Business impact analysis
- B. Common Vulnerability Scoring System
- C. Risk register
- D. Exposure factor

Answer: B

12. Which of the following data states applies to data that is being actively processed by a database server?

- A. In use
- B. At rest
- C. In transit
- D. Being hashed

Answer: A

13. A forensic engineer determines that the root cause of a compromise is a SQL injection attack. Which of the following should the engineer review to identify the command used by the threat actor?

- A. Metadata
- B. Application log
- C. System log
- D. Netflow log

Answer: B

14. A security analyst is reviewing alerts in the SIEM related to potential malicious network traffic coming from an employee's corporate laptop. The security analyst has determined that additional data about the executable running on the machine is necessary to continue the investigation. Which of the following logs should the analyst use as a data source?





- A. Application
- B. IPS/IDS
- C. Network
- D. Endpoint

Answer: D

15. Which of the following activities should a systems administrator perform to quarantine a potentially infected system?

- A. Move the device into an air-gapped environment.
- B. Disable remote log-in through Group Policy.
- C. Convert the device into a sandbox.
- D. Remote wipe the device using the MDM platform.

Answer: A

16. An administrator wants to perform a risk assessment without using proprietary company information. Which of the following methods should the administrator use to gather information?

- A. Network scanning
- B. Penetration testing
- C. Open-source intelligence
- D. Configuration auditing

Answer: C

17. An organization is implementing a COPE mobile device management policy. Which of the following should the organization include in the COPE policy? (Select two).

- A. Remote wiping of the device
- B. Data encryption
- C. Requiring passwords with eight characters
- D. Data usage caps
- E. Employee data ownership
- F. Personal application store access



Answer: A,B

18. An analyst is evaluating the implementation of Zero Trust principles within the data plane. Which of the following would be most relevant for the analyst to evaluate?

- A. Secured zones
- B. Subject role
- C. Adaptive identity
- D. Threat scope reduction

Answer: D

19. Which of the following methods to secure data is most often used to protect data in transit?

- A. Encryption
- B. Obfuscation
- C. Permission restrictions
- D. Hashing

Answer: A

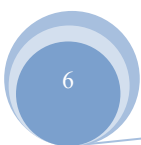
20. A penetration tester was able to gain unauthorized access to a hypervisor platform. Which of the following vulnerabilities was most likely exploited?

- A. Cross-site scripting
- B. SQL injection
- C. Race condition
- D. VM escape

Answer: D

21. A security analyst discovers that a large number of employee credentials had been stolen and were being sold on the dark web. The analyst investigates and discovers that some hourly employee credentials were compromised, but salaried employee credentials were not affected.

Most employees clocked in and out while they were Inside the building using one of the kiosks connected to the network. However, some clocked out and recorded their time after leaving to go home. Only those who





clocked in and out while Inside the building had credentials stolen. Each of the kiosks are on different floors, and there are multiple routers, since the business segments environments for certain business functions. Hourly employees are required to use a website called acmetimekeeping.com to clock in and out. This website is accessible from the internet. Which of the following Is the most likely reason for this compromise?

- A. A brute-force attack was used against the time-keeping website to scan for common passwords.
- B. A malicious actor compromised the time-keeping website with malicious code using an unpatched vulnerability on the site, stealing the credentials.
- C. The internal DNS servers were poisoned and were redirecting acmetimkeeping.com to malicious domain that intercepted the credentials and then passed them through to the real site
- D. ARP poisoning affected the machines in the building and caused the kiosks lo send a copy of all the submitted credentials to a machine.machine.

Answer: B

22. Which of the following could potentially be introduced at the time of side loading?

- A. User impersonation
- B. Rootkit
- C. On-path attack
- D. Buffer overflow

Answer: B

23. Which of the following should be used to select a label for a file based on the file's value, sensitivity, or applicable regulations?

- A. Verification
- B. Certification
- C. Classification
- D. Inventory

Answer: C

24. A company is expanding its threat surface program and allowing individuals to security test the



company's internet-facing application. The company will compensate researchers based on the vulnerabilities discovered. Which of the following best describes the program the company is setting up?

- A. Open-source intelligence
- B. Bug bounty
- C. Red team
- D. Penetration testing

Answer: B

25. Which of the following should a company use to provide proof of external network security testing?

- A. Business impact analysis
- B. Supply chain analysis
- C. Vulnerability assessment
- D. Third-party attestation

Answer: D

26. A company hired a consultant to perform an offensive security assessment covering penetration testing and social engineering.

Which of the following teams will conduct this assessment activity?

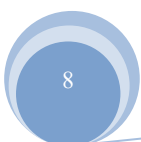
- A. White
- B. Purple
- C. Blue
- D. Red

Answer: D

27. Which of the following allows an exploit to go undetected by the operating system?

- A. Firmware vulnerabilities
- B. Side loading
- C. Memory injection
- D. Encrypted payloads

Answer: A





28. While a user reviews their email, a host gets infected by malware from an external hard drive plugged into the host. The malware steals all the user's credentials stored in the browser. Which of the following training topics should the user review to prevent this situation from reoccurring?

- A. Operational security
- B. Removable media and cables
- C. Password management
- D. Social engineering

Answer: B

29. An engineer moved to another team and is unable to access the new team's shared folders while still being able to access the shared folders from the former team. After opening a ticket, the engineer discovers that the account was never moved to the new group. Which of the following access controls is most likely causing the lack of access? 1

- A. Role-based
- B. Discretionary
- C. Time of day
- D. Least privilege

Answer: A

30. An administrator wants to automate an account permissions update for a large number of accounts. Which of the following would best accomplish this task?

- A. Security groups
- B. Federation
- C. User provisioning
- D. Vertical scaling

Answer: B

31. Which of the following is the best method to reduce the attack surface of an enterprise network?

- A. Disable unused network services on servers.





- B. Use port security for wired connections.
- C. Change default passwords for network printers.
- D. Create a guest wireless network for visitors.

Answer: C

32. Which of the following describes a situation where a user is authorized before being authenticated?

- A. Privilege escalation
- B. Race condition
- C. Tailgating
- D. Impersonation

Answer: D

33. Which of the following techniques would identify whether data has been modified in transit?

- A. Hashing
- B. Tokenization
- C. Masking
- D. Encryption

Answer: A

34. Which of the following cryptographic methods is preferred for securing communications with limited computing resources?

- A. Hashing algorithm
- B. Public key infrastructure
- C. Symmetric encryption
- D. Elliptic curve cryptography

Answer: B

35. A security analyst is investigating an application server and discovers that software on the server is behaving abnormally. The software normally runs batch jobs locally and does not generate traffic, but the process is now generating outbound traffic over random high ports. Which of the following vulnerabilities



has likely been exploited in this software?

- A. Memory injection
- B. Race condition
- C. Side loading
- D. SQL injection

Answer: A

36. Which of the following is the phase in the incident response process when a security analyst reviews roles and responsibilities?

- A. Preparation
- B. Recovery
- C. Lessons learned
- D. Analysis

Answer: A

37. Which of the following is the first step to take when creating an anomaly detection process?

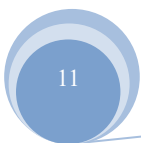
- A. Selecting events
- B. Building a baseline
- C. Selecting logging options
- D. Creating an event log

Answer: B

38. Which of the following would help ensure a security analyst is able to accurately measure the overall risk to an organization when a new vulnerability is disclosed?

- A. A full inventory of all hardware and software
- B. Documentation of system classifications
- C. A list of system owners and their departments
- D. Third-party risk assessment documentation

Answer: A





39. Which of the following is the most important security concern when using legacy systems to provide production service?

- A. Instability
- B. Lack of vendor support
- C. Loss of availability
- D. Use of insecure protocols

Answer: B

40. A systems administrator receives a text message from an unknown number claiming to be the Chief Executive Officer of the company. The message states an emergency situation requires a password reset.

Which of the following threat vectors is being used?

- A. Typosquatting
- B. Smishing
- C. Pretexting
- D. Impersonation

Answer: B

41. Which of the following would be the best way to test resiliency in the event of a primary power failure?

- A. Parallel processing
- B. Tabletop exercise
- C. Simulation testing
- D. Production failover

Answer: D

42. A company is implementing a policy to allow employees to use their personal equipment for work.

However, the company wants to ensure that only company-approved applications can be installed. Which of the following addresses this concern?

- A. MDM
- B. Containerization
- C. DLP



D. FIM

Answer: A

43. A company's online shopping website became unusable shortly after midnight on January 30, 2023. When a security analyst reviewed the database server, the analyst noticed the following code used for backing up data:

Which of the following should the analyst do next?

- A. Check for recently terminated DBAs.
- B. Review WAF logs for evidence of command injection.
- C. Scan the database server for malware.
- D. Search the web server for ransomware notes.

Answer: B

44. Which of the following is a common data removal option for companies that want to wipe sensitive data from hard drives in a repeatable manner but allow the hard drives to be reused?

- A. Sanitization
- B. Formatting
- C. Degaussing
- D. Defragmentation

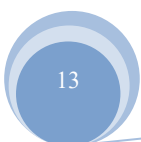
Answer: A

45. Which of the following is the best way to secure an on-site data center against intrusion from an insider?

- A. Bollards
- B. Access badge
- C. Motion sensor
- D. Video surveillance

Answer: B

46. The marketing department set up its own project management software without telling the appropriate departments. Which of the following describes this scenario?





- A. Shadow IT
- B. Insider threat
- C. Data exfiltration
- D. Service disruption

Answer: A

47. Which of the following describes the understanding between a company and a client about what will be provided and the accepted time needed to provide the company with the resources?

- A. SLA
- B. MOU
- C. MOA
- D. BPA

Answer: A

48. A data administrator is configuring authentication for a SaaS application and would like to reduce the number of credentials employees need to maintain. The company prefers to use domain credentials to access new SaaS applications. Which of the following methods would allow this functionality?

- A. SSO
- B. LEAP
- C. MFA
- D. PEAP

Answer: A

49. An employee clicked a malicious link in an email and downloaded malware onto the company's computer network. The malicious program exfiltrated thousands of customer records. Which of the following should the company implement to prevent this in the future?

- A. User awareness training
- B. Network monitoring
- C. Endpoint protection
- D. Data loss prevention



Answer: A

50. Which of the following is the best mitigation for a zero-day vulnerability found in mission- critical production servers that must be highly available?

- A. Virtualizing and migrating to a containerized instance
- B. Removing and sandboxing to an isolated network
- C. Monitoring and implementing compensating controls
- D. Patching and redeploying to production as quickly as possible

Answer: C

51. Which of the following is an example of memory injection?

- A. Two processes access the same variable, allowing one to cause a privilege escalation.
- B. A process receives an unexpected amount of data, which causes malicious code to be executed.
- C. Malicious code is copied to the allocated space of an already running process.
- D. An executable is overwritten on the disk, and malicious code runs the next time it is executed.

Answer: C

52. An organization has a new regulatory requirement to implement corrective controls on a financial system. Which of the following is the most likely reason for the new requirement?

- A. To defend against insider threats altering banking details
- B. To ensure that errors are not passed to other systems
- C. To allow for business insurance to be purchased
- D. To prevent unauthorized changes to financial data

Answer: D

53. A company wants to ensure employees are allowed to copy files from a virtual desktop during the workday but are restricted during non-working hours. Which of the following security measures should the company set up?

- A. Digital rights management
- B. Role-based access control



- C. Time-based access control
- D. Network access control

Answer: C

54. A customer has a contract with a CSP and wants to identify which controls should be implemented in the IaaS enclave. Which of the following is most likely to contain this information?

- A. Statement of work
- B. Responsibility matrix
- C. Service-level agreement
- D. Master service agreement

Answer: B

55. Cadets speaking a foreign language are using company phone numbers to make unsolicited phone calls to a partner organization. A security analyst validates through honeypot system logs that the calls are occurring and the numbers are not being spoofed. Which of the following is the most likely explanation?

- A. The executive team is traveling internationally and trying to avoid roaming charges
- B. The company's SIP server security settings are weak.
- C. Disgruntled employees are making calls to the partner organization.
- D. The service provider has assigned multiple companies the same numbers

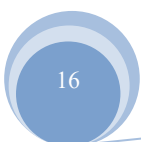
Answer: B

56. During a recent log review, an analyst found evidence of successful injection attacks. Which of the following will best address this issue?

- A. Authentication
- B. Secure cookies
- C. Static code analysis
- D. Input validation

Answer: D

57. Which of the following phases of an incident response involves generating reports?





- A. Recovery
- B. Preparation
- C. Lessons learned
- D. Containment

Answer: C

58. Which of the following would a security administrator use to comply with a secure baseline during a patch update?

- A. Information security policy
- B. Service-level expectations
- C. Standard operating procedure
- D. Test result report

Answer: C

59. A company is discarding a classified storage array and hires an outside vendor to complete the disposal. Which of the following should the company request from the vendor?

- A. Certification
- B. Inventory list
- C. Classification
- D. Proof of ownership

Answer: A

60. Which of the following agreement types defines the time frame in which a vendor needs to respond?

- A. SOW
- B. SLA
- C. MOA
- D. MOU

Answer: B

61. An organization issued new laptops to all employees and wants to provide web filtering both in and out

of the office without configuring additional access to the network. Which of the following types of web filtering should a systems administrator configure?

- A. Agent-based
- B. Centralized proxy
- C. URL scanning
- D. Content categorization

Answer: A

62. HOTSPOT

Select the appropriate attack and remediation from each drop-down list to label the corresponding attack with its remediation.

INSTRUCTIONS

Not all attacks and remediation actions will be used.

If at any time you would like to bring back the initial state of the simulation, please click the Reset All button.



Attack Description	Target	Attack Identified	BEST Preventative or Remediation Action
An attacker sends multiple SYN packets from multiple sources.	Web server	▼ Botnet RAT Logic Bomb Backdoor Virus Spyware Worm Adware Ransomware Keylogger Phishing	▼ Enable DDoS protection Patch vulnerable systems Disable vulnerable services Change the default system password Update the cryptographic algorithms Change the default application password Implement 2FA using push notification Conduct a code review Implement application fuzzing Implement a host-based IPS Disable remote access services
The attack establishes a connection, which allows remote commands to be executed.	User	▼ Botnet RAT Logic Bomb Backdoor Virus Spyware Worm Adware Ransomware Keylogger Phishing	▼ Enable DDoS protection Patch vulnerable systems Disable vulnerable services Change the default system password Update the cryptographic algorithms Change the default application password Implement 2FA using push notification Conduct a code review Implement application fuzzing Implement a host-based IPS Disable remote access services
The attack is self propagating and compromises a SQL database using well-known credentials as it moves through the network.	Database server	▼ Botnet RAT Logic Bomb Backdoor Virus Spyware Worm Adware Ransomware Keylogger Phishing	▼ Enable DDoS protection Patch vulnerable systems Disable vulnerable services Change the default system password Update the cryptographic algorithms Change the default application password Implement 2FA using push notification Conduct a code review Implement application fuzzing Implement a host-based IPS Disable remote access services
The attacker uses hardware to remotely monitor a user's input activity to harvest credentials.	Executive	▼ Botnet RAT Logic Bomb Backdoor Virus Spyware Worm Adware Ransomware Keylogger Phishing	▼ Enable DDoS protection Patch vulnerable systems Disable vulnerable services Change the default system password Update the cryptographic algorithms Change the default application password Implement 2FA using push notification Conduct a code review Implement application fuzzing Implement a host-based IPS Disable remote access services
The attacker embeds hidden access in an internally developed application that bypasses account login.	Application	▼ Botnet RAT Logic Bomb Backdoor Virus Spyware Worm Adware Ransomware Keylogger Phishing	▼ Enable DDoS protection Patch vulnerable systems Disable vulnerable services Change the default system password Update the cryptographic algorithms Change the default application password Implement 2FA using push notification Conduct a code review Implement application fuzzing Implement a host-based IPS Disable remote access services

Answer:



Attack Description	Target	Attack Identified	BEST Preventative or Remediation Action
An attacker sends multiple SYN packets from multiple sources.	Web server	Botnet RAT Logic Bomb Backdoor Virus Spyware Worm Adware Ransomware Keylogger Phishing	Enable DDoS protection Patch vulnerable systems Disable vulnerable services Change the default system password Update the cryptographic algorithms Change the default application password Implement 2FA using push notification Conduct a code review Implement application fuzzing Implement a host-based IPS Disable remote access services
The attack establishes a connection, which allows remote commands to be executed.	User	Botnet RAT Logic Bomb Backdoor Virus Spyware Worm Adware Ransomware Keylogger Phishing	Enable DDoS protection Patch vulnerable systems Disable vulnerable services Change the default system password Update the cryptographic algorithms Change the default application password Implement 2FA using push notification Conduct a code review Implement application fuzzing Implement a host-based IPS Disable remote access services
The attack is self propagating and compromises a SQL database using well-known credentials as it moves through the network.	Database server	Botnet RAT Logic Bomb Backdoor Virus Spyware Worm Adware Ransomware Keylogger Phishing	Enable DDoS protection Patch vulnerable systems Disable vulnerable services Change the default system password Update the cryptographic algorithms Change the default application password Implement 2FA using push notification Conduct a code review Implement application fuzzing Implement a host-based IPS Disable remote access services
The attacker uses hardware to remotely monitor a user's input activity to harvest credentials.	Executive	Botnet RAT Logic Bomb Backdoor Virus Spyware Worm Adware Ransomware Keylogger Phishing	Enable DDoS protection Patch vulnerable systems Disable vulnerable services Change the default system password Update the cryptographic algorithms Change the default application password Implement 2FA using push notification Conduct a code review Implement application fuzzing Implement a host-based IPS Disable remote access services
The attacker embeds hidden access in an internally developed application that bypasses account login.	Application	Botnet RAT Logic Bomb Backdoor Virus Spyware Worm Adware Ransomware Keylogger Phishing	Enable DDoS protection Patch vulnerable systems Disable vulnerable services Change the default system password Update the cryptographic algorithms Change the default application password Implement 2FA using push notification Conduct a code review Implement application fuzzing Implement a host-based IPS Disable remote access services

63. A cybersecurity incident response team at a large company receives notification that malware is present on several corporate desktops. No known Indicators of compromise have been found on the network. Which of the following should the team do first to secure the environment?

- A. Contain the Impacted hosts
- B. Add the malware to the application blocklist.
- C. Segment the core database server.
- D. Implement firewall rules to block outbound beaconing



Answer: A

64. A malicious insider from the marketing team alters records and transfers company funds to a personal account. Which of the following methods would be the best way to secure company records in the future?

- A. Permission restrictions
- B. Hashing
- C. Input validation
- D. Access control list

Answer: D

65. Which of the following provides resilience by hosting critical VMs within different IaaS providers while being maintained by internal application owners?

- A. Multicloud architectures
- B. SaaS provider diversity
- C. On-premises server load balancing
- D. Corporate-owned, off-site locations

Answer: A

66. An employee used a company's billing system to issue fraudulent checks. The administrator is looking for evidence of other occurrences of this activity. Which of the following should the administrator examine?

- A. Application logs
- B. Vulnerability scanner logs
- C. IDS/IPS logs
- D. Firewall logs

Answer: A

67. Which of the following tools is best for logging and monitoring in a cloud environment?

- A. IPS
- B. FIM
- C. NAC



D. SIEM

Answer: D

68. A security administrator recently reset local passwords and the following values were recorded in the system:

Host	Account	MD5 password values
ACCT-PC-1	admin	f1bdf5ed1d7ad7ede4e3809bd35644b0
HR-PC-1	admin	d706ab8258fe67c131ebc57a6e28184
IT-PC-2	admin	f8ddb9cbb321d7dfbf6cb059736f0b3d
FILE-SRV-1	admin	f054bbd2f5ebab9cb5571000b2c60c02
DB-SRV-1	admin	8638f732ba7cf2d95b16979e2725da78

Which of the following in the security administrator most likely protecting against?

- A. Account sharing
- B. Weak password complexity
- C. Pass-the-hash attacks
- D. Password compromise

Answer: C

69. A business uses Wi-Fi with content filleting enabled. An employee noticed a coworker accessed a blocked site from a work computer and reported the issue. While Investigating the issue, a security administrator found another device providing internet access to certain employees. Which of the following best describes the security risk?

- A. The host-based security agent is not running on all computers.
- B. A rogue access point is allowing users to bypass controls.
- C. Employees who have certain credentials are using a hidden SSID.
- D. A valid access point is being jammed to limit availability.

Answer: B

70. A systems administrator is concerned about vulnerabilities within cloud computing instances Which of the following is most important for the administrator to consider when architecting a cloud computing environment?

- A. SQL injection



- B. TOC/TOU
- C. VM escape
- D. Tokenization
- E. Password spraying

Answer: C

71. Which of the following methods would most likely be used to identify legacy systems?

- A. Bug bounty program
- B. Vulnerability scan
- C. Package monitoring
- D. Dynamic analysis

Answer: B

72. A company's Chief Information Security Officer (CISO) wants to enhance the capabilities of the incident response team. The CISO directs the incident response team to deploy a tool that rapidly analyzes host and network data from potentially compromised systems and forwards the data for further review. Which of the following tools should the incident response team deploy?

- A. NAC
- B. IPS
- C. SIEM
- D. EDR

Answer: D

73. A company's accounting department receives an urgent payment message from the company's bank domain with instructions to wire transfer funds. The sender requests that the transfer be completed as soon as possible. Which of the following attacks is described?

- A. Business email compromise
- B. Vishing
- C. Spear phishing
- D. Impersonation



Answer: A

74. A security engineer configured a remote access VPN. The remote access VPN allows end users to connect to the network by using an agent that is installed on the endpoint, which establishes an encrypted tunnel. Which of the following protocols did the engineer most likely implement?

- A. GRE
- B. IPSec
- C. SD-WAN
- D. EAP

Answer: B

75. Which of the following should a security operations center use to improve its incident response procedure?

- A. Playbooks
- B. Frameworks
- C. Baselines
- D. Benchmarks

Answer: A

76. During the onboarding process, an employee needs to create a password for an intranet account. The password must include ten characters, numbers, and letters, and two special characters. Once the password is created, the company will grant the employee access to other company-owned websites based on the intranet profile. Which of the following access management concepts is the company most likely using to safeguard intranet accounts and grant access to multiple sites based on a user's intranet account? (Select two).

- A. Federation
- B. Identity proofing
- C. Password complexity
- D. Default password changes
- E. Password manager



F. Open authentication

Answer: A,C

77. A program manager wants to ensure contract employees can only use the company's computers Monday through Friday from 9 a.m. to 5 p.m. Which of the following would best enforce this access control?

- A. Creating a GPO for all contract employees and setting time-of-day log-in restrictions
- B. Creating a discretionary access policy and setting rule-based access for contract employees
- C. Implementing an OAuth server and then setting least privilege for contract employees
- D. Implementing SAML with federation to the contract employees' authentication server

Answer: A

78. A U.S.-based cloud-hosting provider wants to expand its data centers to new international locations. Which of the following should the hosting provider consider first?

- A. Local data protection regulations
- B. Risks from hackers residing in other countries
- C. Impacts to existing contractual obligations
- D. Time zone differences in log correlation

Answer: A

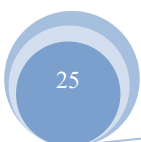
79. An accounting employee recently used software that was not approved by the company. Which of the following risks does this most likely represent?

- A. Unskilled attacker
- B. Hacktivist
- C. Shadow IT
- D. Supply chain

Answer: C

80. Which of the following is a common, passive reconnaissance technique employed by penetration testers in the early phases of an engagement?

- A. Open-source intelligence





- B. Port scanning
- C. Pivoting
- D. Exploit validation

Answer: A

81. Which of the following is the most likely outcome if a large bank fails an internal PCI DSS compliance assessment?

- A. Fines
- B. Audit findings
- C. Sanctions
- D. Reputation damage

Answer: A

82. A company is concerned about weather events causing damage to the server room and downtime. Which of the following should the company consider?

- A. Clustering servers
- B. Geographic dispersion
- C. Load balancers
- D. Off-site backups

Answer: B

83. Which of the following environments utilizes a subset of customer data and is most likely to be used to assess the impacts of major system upgrades and demonstrate system features?

- A. Development
- B. Test
- C. Production
- D. Staging

Answer: D

84. A security consultant needs secure, remote access to a client environment. Which of the following



should the security consultant most likely use to gain access?

- A. EAP
- B. DHCP
- C. IPSec
- D. NAT

Answer: C

85. Which of the following best protects sensitive data in transit across a geographically dispersed Infrastructure?

- A. Encryption
- B. Masking
- C. Tokenization
- D. Obfuscation

Answer: A

86. Which of the following is a hardware-specific vulnerability?

- A. Firmware version
- B. Buffer overflow
- C. SQL injection
- D. Cross-site scripting

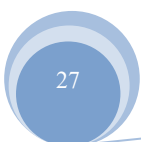
Answer: A

87. Which of the following is used to validate a certificate when it is presented to a user?

- A. OCSP
- B. CSR
- C. CA
- D. CRC

Answer: A

88. Which of the following is a qualitative approach to risk analysis?





- A. Including the MTTR and MTBF as part of the risk assessment
- B. Tracking and documenting network risks using a risk register
- C. Assigning a level of high, medium, or low to the risk rating
- D. Using ALE and ARO to help determine whether a risk should be mitigated

Answer: C

89. Which of the following can best contribute to prioritizing patch applications?

- A. CVSS
- B. SCAP
- C. OSINT
- D. CVE

Answer: A

90. A company decides to purchase an insurance policy. Which of the following risk management strategies is this company implementing?

- A. Mitigate
- B. Accept
- C. Avoid
- D. Transfer

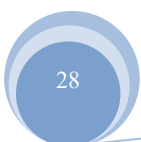
Answer: D

91. Which of the following would best ensure a controlled version release of a new software application?

- A. Business continuity planning
- B. Quantified risk analysis
- C. Static code analysis
- D. Change management procedures

Answer: D

92. One of a company's vendors sent an analyst a security bulletin that recommends a BIOS update. Which of the following vulnerability types is being addressed by the patch?





- A. Virtualization
- B. Firmware
- C. Application
- D. Operating system

Answer: B

93. An organization has too many variations of a single operating system and needs to standardize the arrangement prior to pushing the system image to users. Which of the following should the organization implement first?

- A. Standard naming convention
- B. Mashing
- C. Network diagrams
- D. Baseline configuration

Answer: D

94. Malware spread across a company's network after an employee visited a compromised industry blog. Which of the following best describes this type of attack?

- A. Impersonation
- B. Disinformation
- C. Watering-hole
- D. Smishing

Answer: C

95. Which of the following provides the best protection against unwanted or insecure communications to and from a device?

- A. System hardening
- B. Host-based firewall
- C. Intrusion detection system
- D. Anti-malware software

Answer: B



96. An organization experiences a cybersecurity incident involving a command-and-control server. Which of the following logs should be analyzed to identify the impacted host? (Select two).

- A. Application
- B. Authentication
- C. DHCP
- D. Network
- E. Firewall
- F. Database

Answer: C,E

97. An IT security team is concerned about the confidentiality of documents left unattended in MFPs. Which of the following should the security team do to mitigate the situation?

- A. Educate users about the importance of paper shredder devices.
- B. Deploy an authentication factor that requires In-person action before printing.
- C. Install a software client on every computer authorized to use the MFPs.
- D. Update the management software to utilize encryption.

Answer: B

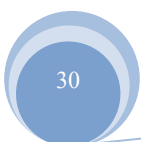
98. A technician needs to apply a high-priority patch to a production system. Which of the following steps should be taken first?

- A. Air gap the system.
- B. Move the system to a different network segment.
- C. Create a change control request.
- D. Apply the patch to the system.

Answer: C

99. A systems administrator is looking for a low-cost application-hosting solution that is cloud-based. Which of the following meets these requirements?

- A. Serverless framework





- B. Type 1 hypervisor
- C. SD-WAN
- D. SDN

Answer: A

100. A security analyst created a fake account and saved the password in a non-readily accessible directory in a spreadsheet. An alert was also configured to notify the security team if the spreadsheet is opened. Which of the following best describes the deception method being deployed?

- A. Honeypot
- B. Honey account
- C. Honeytoken
- D. Honeynet

Answer: C

101. Employees located off-site must have access to company resources in order to complete their assigned tasks. These employees utilize a solution that allows remote access without interception concerns. Which of the following best describes this solution?

- A. Proxy server
- B. NGFW
- C. VPN
- D. Security zone

Answer: C

102. An administrator finds that all user workstations and servers are displaying a message that is associated with files containing an extension of .ryk. Which of the following types of infections is present on the systems?

- A. Virus
- B. Trojan
- C. Spyware
- D. Ransomware



Answer: D

103. After a series of account compromises and credential misuse, a company hires a security manager to develop a security program. Which of the following steps should the security manager take first to increase security awareness?

- A. Evaluate tools that identify risky behavior and distribute reports on the findings.
- B. Send quarterly newsletters that explain the importance of password management.
- C. Develop phishing campaigns and notify the management team of any successes.
- D. Update policies and handbooks to ensure all employees are informed of the new procedures.

Answer: D

104. Which of the following should be used to ensure an attacker is unable to read the contents of a mobile device's drive if the device is lost?

- A. TPM
- B. ECC
- C. FDE
- D. HSM

Answer: C

105. Prior to implementing a design change, the change must go through multiple steps to ensure that it does not cause any security issues. Which of the following is most likely to be one of those steps?

- A. Management review
- B. Load testing
- C. Maintenance notifications
- D. Procedure updates

Answer: A

106. A company implemented an MDM policy to mitigate risks after repeated instances of employees losing company-provided mobile phones. In several cases, the lost phones were used maliciously to perform social engineering attacks against other employees. Which of the following MDM features should



be configured to best address this issue?

(Select two).

- A. Screen locks
- B. Remote wipe
- C. Full device encryption
- D. Push notifications
- E. Application management
- F. Geolocation

Answer: A,B

107. Which of the following is a type of vulnerability that involves inserting scripts into web- based applications in order to take control of the client's web browser?

- A. SQL injection
- B. Cross-site scripting
- C. Zero-day exploit
- D. On-path attack

Answer: B

108. Which of the following is a compensating control for providing user access to a high-risk website?

- A. Enabling threat prevention features on the firewall
- B. Configuring a SIEM tool to capture all web traffic
- C. Setting firewall rules to allow traffic from any port to that destination
- D. Blocking that website on the endpoint protection software

Answer: A

109. Which of the following types of vulnerabilities is primarily caused by improper use and management of cryptographic certificates?

- A. Misconfiguration
- B. Resource reuse
- C. Insecure key storage



D. Weak cipher suites

Answer: C

110. Users at a company are reporting they are unable to access the URL for a new retail website because it is flagged as gambling and is being blocked.

Which of the following changes would allow users to access the site?

- A. Creating a firewall rule to allow HTTPS traffic
- B. Configuring the IPS to allow shopping
- C. Tuning the DLP rule that detects credit card data
- D. Updating the categorization in the content filter

Answer: D

111. Which of the following agreements defines response time, escalation points, and performance metrics?

- A. BPA
- B. MOA
- C. NDA
- D. SLA

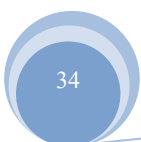
Answer: D

112. Which of the following risk management strategies should an enterprise adopt first if a legacy application is critical to business operations and there are preventative controls that are not yet implemented?

- A. Mitigate
- B. Accept
- C. Transfer
- D. Avoid

Answer: A

113. While considering the organization's cloud-adoption strategy, the Chief Information Security Officer





sets a goal to outsource patching of firmware, operating systems, and applications to the chosen cloud vendor. Which of the following best meets this goal?

- A. Community cloud
- B. PaaS
- C. Containerization
- D. Private cloud
- E. SaaS
- F. IaaS

Answer: E

114. Which of the following would a systems administrator follow when upgrading the firmware of an organization's router?

- A. Software development life cycle
- B. Risk tolerance
- C. Certificate signing request
- D. Maintenance window

Answer: D

115. An engineer needs to find a solution that creates an added layer of security by preventing unauthorized access to internal company resources. Which of the following would be the best solution?

- A. RDP server
- B. Jump server
- C. Proxy server
- D. Hypervisor

Answer: B

116. Which of the following is the most important element when defining effective security governance?

- A. Discovering and documenting external considerations
- B. Developing procedures for employee onboarding and offboarding
- C. Assigning roles and responsibilities for owners, controllers, and custodians



D. Defining and monitoring change management procedures

Answer: C

117. An employee recently resigned from a company. The employee was responsible for managing and supporting weekly batch jobs over the past five years. A few weeks after the employee resigned, one of the batch jobs failed and caused a major disruption. Which of the following would work best to prevent this type of incident from reoccurring?

- A. Job rotation
- B. Retention
- C. Outsourcing
- D. Separation of duties

Answer: A

118. An administrator is reviewing a single server's security logs and discovers the following;
Which of the following best describes the action captured in this log file?

- A. Brute-force attack
- B. Privilege escalation
- C. Failed password audit
- D. Forgotten password by the user

Answer: A

119. Which of the following vulnerabilities is exploited when an attacker overwrites a register with a malicious address?

- A. VM escape
- B. SQL injection
- C. Buffer overflow
- D. Race condition

Answer: C

120. An employee receives a text message that appears to have been sent by the payroll department and



is asking for credential verification. Which of the following social engineering techniques are being attempted? (Choose two.)

- A. Typosquatting
- B. Phishing
- C. Impersonation
- D. Vishing
- E. Smishing
- F. Misinformation

Answer: B,E

121. A company is working with a vendor to perform a penetration test. Which of the following includes an estimate about the number of hours required to complete the engagement?

- A. SOW
- B. BPA
- C. SLA
- D. NDA

Answer: A

122. Which of the following would enable a data center to remain operational through a multiday power outage?

- A. Generator
- B. Uninterruptible power supply
- C. Replication
- D. Parallel processing

Answer: A

123. An organization plans to expand its operations internationally and needs to keep data at the new location secure. The organization wants to use the most secure architecture model possible. Which of the following models offers the highest level of security?

- A. Cloud-based



- B. Peer-to-peer
- C. On-premises
- D. Hybrid

Answer: A

124. A company wants to get alerts when others are researching and doing reconnaissance on the company. One approach would be to host a part of the Infrastructure online with known vulnerabilities that would appear to be company assets. Which of the following describes this approach?

- A. Watering hole
- B. Bug bounty
- C. DNS sinkhole
- D. Honeypot

Answer: D

125. An organization is leveraging a VPN between its headquarters and a branch location. Which of the following is the VPN protecting?

- A. Data in use
- B. Data in transit
- C. Geographic restrictions
- D. Data sovereignty

Answer: B

126. A software development manager wants to ensure the authenticity of the code created by the company. Which of the following options is the most appropriate?

- A. Testing input validation on the user input fields
- B. Performing code signing on company-developed software
- C. Performing static code analysis on the software
- D. Ensuring secure cookies are use

Answer: B



127. Which of the following security controls would best guard a payroll system against insider manipulation threats?

- A. Compensating
- B. Deterrent
- C. Detective
- D. Corrective

Answer: C

128. The Chief Information Security Officer wants to discuss options for a disaster recovery site that allows the business to resume operations as quickly as possible. Which of the following solutions meets this requirement?

- A. Hot site
- B. Cold site
- C. Geographic dispersion
- D. Warm site

Answer: A

129. Which of the following describes a security alerting and monitoring tool that collects system, application, and network logs from multiple sources in a centralized system?

- A. SIEM
- B. DLP
- C. IDS
- D. SNMP

Answer: A

130. An organization is required to provide assurance that its controls are properly designed and operating effectively. Which of the following reports will best achieve the objective?

- A. Red teaming
- B. Penetration testing
- C. Independent audit



D. Vulnerability assessment

Answer: D

131. Which of the following would be the best way to block unknown programs from executing?

- A. Access control list
- B. Application allow list.
- C. Host-based firewall
- D. DLP solution

Answer: B

132. An organization implemented cloud-managed IP cameras to monitor building entry points and sensitive areas. The service provider enables direct TCP/IP connection to stream live video footage from each camera. The organization wants to ensure this stream is encrypted and authenticated. Which of the following protocols should be implemented to best meet this objective?

- A. SSH
- B. SRTP
- C. S/MIME
- D. PPTP

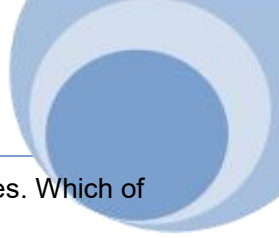
Answer: B

133. A systems administrator wants to prevent users from being able to access data based on their responsibilities. The administrator also wants to apply the required access structure via a simplified format. Which of the following should the administrator apply to the site recovery resource group?

- A. RBAC
- B. ACL
- C. SAML
- D. GPO

Answer: A

134. Company A jointly develops a product with Company B, which is located in a different country.



Company A finds out that their intellectual property is being shared with unauthorized companies. Which of the following has been breached?

- A. SLA
- B. AUP
- C. SOW
- D. MOA

Answer: D

135. Which of the following would be the best way to handle a critical business application that is running on a legacy server?

- A. Segmentation
- B. Isolation
- C. Hardening
- D. Decommissioning

Answer: C

136. A systems administrator is redesigning how devices will perform network authentication. The following requirements need to be met:

- An existing Internal certificate must be used.
- Wired and wireless networks must be supported
- Any unapproved device should be Isolated in a quarantine subnet
- Approved devices should be updated before accessing resources

Which of the following would best meet the requirements?

- A. 802.1X
- B. EAP
- C. RADIUS
- D. WPA2

Answer: A

137. Which of the following can best protect against an employee inadvertently installing malware on a



company system?

- A. Host-based firewall
- B. System isolation
- C. Least privilege
- D. Application allow list

Answer: D

138. Which of the following security concepts is the best reason for permissions on a human resources fileshare to follow the principle of least privilege?

- A. Integrity
- B. Availability
- C. Confidentiality
- D. Non-repudiation

Answer: C

139. Which of the following involves an attempt to take advantage of database misconfigurations?

- A. Buffer overflow
- B. SQL injection
- C. VM escape
- D. Memory injection

Answer: B

140. An organization failed to account for the right-to-be-forgotten regulations. Which of the following impacts might this action have on the company?

- A. Fines
- B. Data breaches
- C. Revenue loss
- D. Blackmail

Answer: A



141. A security team created a document that details the order in which critical systems should be brought back online after a major outage. Which of the following documents did the team create?

- A. Communication plan
- B. Incident response plan
- C. Data retention policy
- D. Disaster recovery plan

Answer: D

142. The Chief Information Security Officer of an organization needs to ensure recovery from ransomware would likely occur within the organization's agreed-upon RPOs and RTOs. Which of the following backup scenarios would best ensure recovery?

- A. Hourly differential backups stored on a local SAN array
- B. Daily full backups stored on premises in magnetic offline media
- C. Daily differential backups maintained by a third-party cloud provider
- D. Weekly full backups with daily incremental stored on a NAS drive

Answer: D

143. Which of the following is used to quantitatively measure the criticality of a vulnerability?

- A. CVE
- B. CVSS
- C. CIA
- D. CERT

Answer: B

144. The Chief Information Security Officer (CISO) asks a security analyst to install an OS update to a production VM that has a 99% uptime SLA. The CISO tells the analyst the installation must be done as quickly as possible. Which of the following courses of action should the security analyst take first?

- A. Log in to the server and perform a health check on the VM.
- B. Install the patch immediately.
- C. Confirm that the backup service is running.



D. Take a snapshot of the VM.

Answer: D

145. During a penetration test in a hypervisor, the security engineer is able to inject a malicious payload and access the host filesystem. Which of the following best describes this vulnerability?

- A. VM escape
- B. Cross-site scripting
- C. Malicious update
- D. SQL injection

Answer: A

146. A security analyst scans a company's public network and discovers a host is running a remote desktop that can be used to access the production network. Which of the following changes should the security analyst recommend?

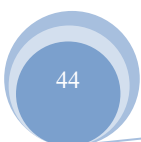
- A. Changing the remote desktop port to a non-standard number
- B. Setting up a VPN and placing the jump server inside the firewall
- C. Using a proxy for web connections from the remote desktop server
- D. Connecting the remote server to the domain and increasing the password length

Answer: B

147. A company's end users are reporting that they are unable to reach external websites. After reviewing the performance data for the DNS servers, the analyst discovers that the CPU, disk, and memory usage are minimal, but the network interface is flooded with inbound traffic. Network logs show only a small number of DNS queries sent to this server. Which of the following best describes what the security analyst is seeing?

- A. Concurrent session usage
- B. Secure DNS cryptographic downgrade
- C. On-path resource consumption
- D. Reflected denial of service

Answer: D





148. Which of the following actions could a security engineer take to ensure workstations and servers are properly monitored for unauthorized changes and software?

- A. Configure all systems to log scheduled tasks.
- B. Collect and monitor all traffic exiting the network.
- C. Block traffic based on known malicious signatures.
- D. Install endpoint management software on all systems.

Answer: D

149. A remote employee navigates to a shopping website on their company-owned computer. The employee clicks a link that contains a malicious file. Which of the following would prevent this file from downloading?

- A. DLP
- B. FIM
- C. NAC
- D. EDR

Answer: D

150. A company with a high-availability website is looking to harden its controls at any cost. The company wants to ensure that the site is secure by finding any possible issues. Which of the following would most likely achieve this goal?

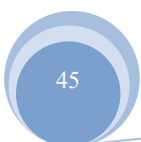
- A. Permission restrictions
- B. Bug bounty program
- C. Vulnerability scan
- D. Reconnaissance

Answer: B

151. While investigating a possible incident, a security analyst discovers the following log entries:

* 67.118.34.157 ----- [28/Jul/2022:10:26:59 -0300] "GET /query.php?q=wireless%20headphones / HTTP/1.0" 200 12737

* 132.18.222.103 ----[28/Jul/2022:10:27:10 -0300] "GET /query.php?q=123 INSERT INTO users



VALUES('temp', 'pass123')# / HTTP/1.0" 200 935

* 12.45.101.121 ----- [28/Jul/2022:10:27:22 -0300] "GET /query.php?q=mp3%20players I HTTP/1.0" 200 14650

Which of the following should the analyst do first?

- A. Implement a WAF
- B. Disable the query .php script
- C. Block brute-force attempts on temporary users
- D. Check the users table for new accounts

Answer: D

152. Which of the following can be used to identify potential attacker activities without affecting production servers?

- A. Honey pot
- B. Video surveillance
- C. Zero Trust
- D. Geofencing

Answer: A

153. Which of the following aspects of the data management life cycle is most directly impacted by local and international regulations?

- A. Destruction
- B. Certification
- C. Retention
- D. Sanitization

Answer: C

154. A systems administrator wants to implement a backup solution. the solution needs to allow recovery of the entire system, including the operating system, in case of a disaster. Which of the following backup types should the administrator consider?

- A. Incremental



- B. Storage area network
- C. Differential
- D. Image

Answer: D

155. A systems administrator works for a local hospital and needs to ensure patient data is protected and secure. Which of the following data classifications should be used to secure patient data?

- A. Private
- B. Critical
- C. Sensitive
- D. Public

Answer: C

156. Which of the following activities would involve members of the incident response team and other stakeholders simulating an event?

- A. Lessons learned
- B. Digital forensics
- C. Tabletop exercise
- D. Root cause analysis

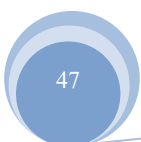
Answer: C

157. In order to strengthen a password and prevent a hacker from cracking it, a random string of 36 characters was added to the password. Which of the following best describes this technique?

- A. Key stretching
- B. Tokenization
- C. Data masking
- D. Salting

Answer: D

158. The security team notices that the Always On VPN solution sometimes fails to connect. This leaves





remote users unprotected because they cannot connect to the on-premises web proxy. Which of the following changes will best provide web protection in this scenario?

- A. Implement network access control.
- B. Configure the local gateway to point to the VPN.
- C. Create a public NAT to the on-premises proxy.
- D. Install a host-based content filtering solution.

Answer: D

159. In a rush to meet an end-of-year business goal, the IT department was told to implement a new business application. The security engineer reviews the attributes of the application and decides the time needed to perform due diligence is insufficient from a cybersecurity perspective. Which of the following best describes the security engineer's response?

- A. Risk tolerance
- B. Risk acceptance
- C. Risk importance
- D. Risk appetite

Answer: D

160. Which of the following documents details how to accomplish a technical security task?

- A. Standard
- B. Policy
- C. Guideline
- D. Procedure

Answer: D

161. Which of the following best describe why a process would require a two-person integrity security control?

- A. To Increase the chance that the activity will be completed in half of the time the process would take only one user to complete
- B. To permit two users from another department to observe the activity that is being performed by an



authorized user

- C. To reduce the risk that the procedures are performed incorrectly or by an unauthorized user
- D. To allow one person to perform the activity while being recorded on the CCTV camera

Answer: C

162. A company processes and stores sensitive data on its own systems. Which of the following steps should the company take first to ensure compliance with privacy regulations?

- A. Implement access controls and encryption.
- B. Develop and provide training on data protection policies.
- C. Create incident response and disaster recovery plans.
- D. Purchase and install security software.

Answer: A

163. An incident response specialist must stop a malicious attack from expanding to other parts of an organization. Which of the following should the incident response specialist perform first?

- A. Eradication
- B. Recovery
- C. Containment
- D. Simulation

Answer: C

164. An administrator is installing an SSL certificate on a new system. During testing, errors indicate that the certificate is not trusted. The administrator has verified with the issuing CA and has validated the private key. Which of the following should the administrator check for next?

- A. If the wildcard certificate is configured
- B. If the certificate signing request is valid
- C. If the root certificate is installed
- D. If the public key is configured

Answer: C



165. A vendor salesperson is a personal friend of a company's Chief Financial Officer (CFO). The company recently made a large purchase from the vendor, which was directly approved by the CFO. Which of the following best describes this situation?

- A. Rules of engagement
- B. Conflict of interest
- C. Due diligence
- D. Contractual impact
- E. Reputational damage

Answer: B

166. A systems administrator just purchased multiple network devices. Which of the following should the systems administrator perform to prevent attackers from accessing the devices by using publicly available information?

- A. Install endpoint protection
- B. Disable ports/protocols
- C. Change default passwords
- D. Remove unnecessary software

Answer: C

167. A software developer wishes to implement an application security technique that will provide assurance of the application's integrity. Which of the following techniques will achieve this?

- A. Secure cookies
- B. Input validation
- C. Static analysis
- D. Code signing

Answer: D

168. Which of the following exercises should an organization use to improve its incident response process?

- A. Tabletop
- B. Replication



- C. Failover
- D. Recovery

Answer: A

169. Security controls in a data center are being reviewed to ensure data is properly protected and that human life considerations are included. Which of the following best describes how the controls should be set up?

- A. Remote access points should fail closed.
- B. Logging controls should fail open.
- C. Safety controls should fail open.
- D. Logical security controls should fail closed.

Answer: C

170. Which of the following is the first step to secure a newly deployed server?

- A. Close unnecessary service ports.
- B. Update the current version of the software.
- C. Add the device to the ACL.
- D. Upgrade the OS version.

Answer: A

171. Which of the following incident response activities ensures evidence is properly handled?

- A. E-discovery
- B. Chain of custody
- C. Legal hold
- D. Preservation

Answer: B

172. Which of the following would be most useful in determining whether the long-term cost to transfer a risk is less than the impact of the risk?

- A. ARO



- B. RTO
- C. RPO
- D. ALE
- E. SLE

Answer: D

173. An administrator investigating an incident is concerned about the downtime of a critical server due to a failed drive. Which of the following would the administrator use to estimate the time needed to fix the issue?

- A. MTTR
- B. MTBF
- C. RTO
- D. RPO

Answer: A

174. A company's legal department drafted sensitive documents in a SaaS application and wants to ensure the documents cannot be accessed by individuals in high-risk countries. Which of the following is the most effective way to limit this access?

- A. Data masking
- B. Encryption
- C. Geolocation policy
- D. Data sovereignty regulation

Answer: C

175. Visitors to a secured facility are required to check in with a photo ID and enter the facility through an access control vestibule. Which of the following best describes this form of security control?

- A. Physical
- B. Managerial
- C. Technical
- D. Operational

Answer: A



176. A company needs to provide administrative access to internal resources while minimizing the traffic allowed through the security boundary. Which of the following methods is most secure?

- A. Implementing a bastion host
- B. Deploying a perimeter network
- C. Installing a WAF
- D. Utilizing single sign-on

Answer: A

177. While updating the security awareness training, a security analyst wants to address issues created if vendors' email accounts are compromised. Which of the following recommendations should the security analyst include in the training?

- A. Refrain from clicking on images included in emails from new vendors.
- B. Delete emails from unknown service provider partners.
- C. Require that invoices be sent as attachments.
- D. Be alert to unexpected requests from familiar email addresses.

Answer: D

178. Which of the following activities should be performed first to compile a list of vulnerabilities in an environment?

- A. Automated scanning
- B. Penetration testing
- C. Threat hunting
- D. Log aggregation
- E. Adversarial emulation

Answer: A

179. Which of the following should a security administrator adhere to when setting up a new set of firewall rules?

- A. Disaster recovery plan



- B. Incident response procedure
- C. Business continuity plan
- D. Change management procedure

Answer: D

180. An employee who was working remotely lost a mobile device containing company data. Which of the following provides the best solution to prevent future data loss?

- A. MDM
- B. DLP
- C. FDE
- D. EDR

Answer: A

181. An organization's internet-facing website was compromised when an attacker exploited a buffer overflow. Which of the following should the organization deploy to best protect against similar attacks in the future?

- A. NGFW
- B. WAF
- C. TLS
- D. SD-WAN

Answer: B

182. An organization is adopting cloud services at a rapid pace and now has multiple SaaS applications in use. Each application has a separate log-in, so the security team wants to reduce the number of credentials each employee must maintain. Which of the following is the first step the security team should take?

- A. Enable SAML
- B. Create OAuth tokens.
- C. Use password vaulting.
- D. Select an IdP

Answer: D



183. Which of the following must be considered when designing a high-availability network? (Select two).

- A. Ease of recovery
- B. Ability to patch
- C. Physical isolation
- D. Responsiveness
- E. Attack surface
- F. Extensible authentication

Answer: A,E

184. Which of the following architecture models ensures that critical systems are physically isolated from the network to prevent access from users with remote access privileges?

- A. Segmentation
- B. Virtualized
- C. Air-gapped
- D. Serverless

Answer: C

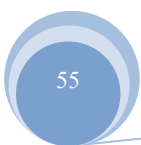
185. Which of the following is the best way to improve the confidentiality of remote connections to an enterprise's infrastructure?

- A. Firewalls
- B. Virtual private networks
- C. Extensive logging
- D. Intrusion detection systems

Answer: B

186. A user is attempting to patch a critical system, but the patch fails to transfer. Which of the following access controls is most likely inhibiting the transfer?

- A. Attribute-based
- B. Time of day





- C. Role-based
- D. Least privilege

Answer: D

187. An organization is struggling with scaling issues on its VPN concentrator and internet circuit due to remote work. The organization is looking for a software solution that will allow it to reduce traffic on the VPN and internet circuit, while still providing encrypted tunnel access to the data center and monitoring of remote employee internet traffic. Which of the following will help achieve these objectives?

- A. Deploying a SASE solution to remote employees
- B. Building a load-balanced VPN solution with redundant internet
- C. Purchasing a low-cost SD-WAN solution for VPN traffic
- D. Using a cloud provider to create additional VPN concentrators

Answer: A

188. While reviewing logs, a security administrator identifies the following code:

```
<script>function(send_info)</script>
```

Which of the following best describes the vulnerability being exploited?

- A. XSS
- B. SQLi
- C. DDoS
- D. CSRF

Answer: A

189. An administrator assists the legal and compliance team with ensuring information about customer transactions is archived for the proper time period. Which of the following data policies is the administrator carrying out?

- A. Compromise
- B. Retention
- C. Analysis
- D. Transfer



E. Inventory

Answer: B

190. The help desk receives multiple calls that machines with an outdated OS version are running slowly. Several users are seeing virus detection alerts. Which of the following mitigation techniques should be reviewed first?

- A. Patching
- B. Segmentation
- C. Monitoring
- D. Isolation

Answer: A

191. Which of the following describes the reason root cause analysis should be conducted as part of incident response?

- A. To gather IoCs for the investigation
- B. To discover which systems have been affected
- C. To eradicate any trace of malware on the network
- D. To prevent future incidents of the same nature

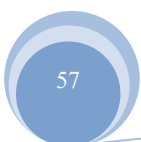
Answer: D

192. A company evaluates several options that would allow employees to have remote access to the network. The security team wants to ensure the solution includes AAA to comply with internal security policies. Which of the following should the security team recommend?

- A. IPSec with RADIUS
- B. RDP connection with LDAPS
- C. Web proxy for all remote traffic
- D. Jump server with 802.1X

Answer: A

193. The security operations center is researching an event concerning a suspicious IP address A security





analyst looks at the following event logs and discovers that a significant portion of the user accounts have experienced faded log-in attempts when authenticating from the same IP address:

```
184.168.131.241 - userA - failed authentication
184.168.131.241 - userA - failed authentication
184.168.131.241 - userB - failed authentication
184.168.131.241 - userB - failed authentication
184.168.131.241 - userC - failed authentication
184.168.131.241 - userC - failed authentication
```

Which of the following most likely describes attack that took place?

- A. Spraying
- B. Brute-force
- C. Dictionary
- D. Rainbow table

Answer: A

194. Which of the following would best explain why a security analyst is running daily vulnerability scans on all corporate endpoints?

- A. To track the status of patch installations
- B. To find shadow IT cloud deployments
- C. To continuously monitor hardware inventory
- D. To hunt for active attackers in the network

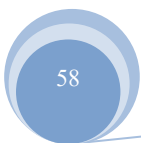
Answer: A

195. Which of the following describes an executive team that is meeting in a board room and testing the company's incident response plan?

- A. Continuity of operations
- B. Capacity planning
- C. Tabletop exercise
- D. Parallel processing

Answer: C

196. A cyber operations team informs a security analyst about a new tactic malicious actors are using to compromise networks.





SIEM alerts have not yet been configured. Which of the following best describes what the security analyst should do to identify this behavior?

- A. [Digital forensics
- B. E-discovery
- C. Incident response
- D. Threat hunting

Answer: D

197. Which of the following data protection strategies can be used to confirm file integrity?

- A. Masking
- B. Encryption
- C. Hashing
- D. Obfuscation

Answer: C

198. During a SQL update of a database, a temporary field used as part of the update sequence was modified by an attacker before the update completed in order to allow access to the system. Which of the following best describes this type of vulnerability?

- A. Race condition
- B. Memory injection
- C. Malicious update
- D. Side loading

Answer: A

199. A company installed cameras and added signs to alert visitors that they are being recorded. Which of the following controls did the company implement? (Select two).

- A. Directive
- B. Deterrent
- C. Preventive
- D. Detective



E. Corrective

F. Technical

Answer: B,D

200. A penetration tester begins an engagement by performing port and service scans against the client environment according to the rules of engagement. Which of the following reconnaissance types is the tester performing?

A. Active

B. Passive

C. Defensive

D. Offensive

Answer: A

201. A company makes a change during the appropriate change window, but the unsuccessful change extends beyond the scheduled time and impacts customers. Which of the following would prevent this from reoccurring?

A. User notification

B. Change approval

C. Risk analysis

D. Backout plan

Answer: D

202. Various stakeholders are meeting to discuss their hypothetical roles and responsibilities in a specific situation, such as a security incident or major disaster. Which of the following best describes this meeting?

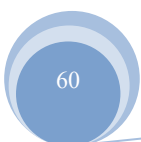
A. Penetration test

B. Continuity of operations planning

C. Tabletop exercise

D. Simulation

Answer: C





203. Which of the following best describe a penetration test that resembles an actual external attack?

- A. Known environment
- B. Partially known environment
- C. Bug bounty
- D. Unknown environment

Answer: D

204. Which of the following consequences would a retail chain most likely face from customers in the event the retailer is non-compliant with PCI DSS?

- A. Contractual impacts
- B. Sanctions
- C. Fines
- D. Reputational damage

Answer: A

205. Which of the following actions best addresses a vulnerability found on a company's web server?

- A. Patching
- B. Segmentation
- C. Decommissioning
- D. Monitoring

Answer: A

206. Which of the following factors are the most important to address when formulating a training curriculum plan for a security awareness program? (Select two).

- A. Channels by which the organization communicates with customers
- B. The reporting mechanisms for ethics violations
- C. Threat vectors based on the industry in which the organization operates
- D. Secure software development training for all personnel
- E. Cadence and duration of training events
- F. Retraining requirements for individuals who fail phishing simulations



Answer: C,E

207. A systems administrator creates a script that validates OS version, patch levels, and installed applications when users log in. Which of the following examples best describes the purpose of this script?

- A. Resource scaling
- B. Policy enumeration
- C. Baseline enforcement
- D. Guardrails implementation

Answer: C

208. Which of the following is the best way to prevent data from being leaked from a secure network that does not need to communicate externally?

- A. Air gap
- B. Containerization
- C. Virtualization
- D. Decentralization

Answer: A

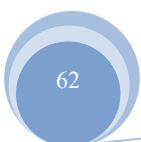
209. While troubleshooting a firewall configuration, a technician determines that a “deny any” policy should be added to the bottom of the ACL. The technician updates the policy, but the new policy causes several company servers to become unreachable.

Which of the following actions would prevent this issue?

- A. Documenting the new policy in a change request and submitting the request to change management
- B. Testing the policy in a non-production environment before enabling the policy in the production network
- C. Disabling any intrusion prevention signatures on the 'deny any*' policy prior to enabling the new policy
- D. Including an 'allow any1 policy above the 'deny any* policy

Answer: B

210. Which of the following can be best used to discover a company's publicly available breach information?





- A. OSINT
- B. SIEM
- C. CVE
- D. CVSS

Answer: A

211. Which of the following security concepts is accomplished with the installation of a RADIUS server?

- A. CIA
- B. AA
- C. ACL
- D. PEM

Answer: B

212. A systems administrator notices that the research and development department is not using the company VPN when accessing various company-related services and systems. Which of the following scenarios describes this activity?

- A. Espionage
- B. Data exfiltration
- C. Nation-state attack
- D. Shadow IT

Answer: D

213. An employee receives a text message from an unknown number claiming to be the company's Chief Executive Officer and asking the employee to purchase several gift cards. Which of the following types of attacks does this describe?

- A. Vishing
- B. Smishing
- C. Pretexting
- D. Phishing

Answer: B



214. Which of the following security control types does an acceptable use policy best represent?

- A. Detective
- B. Compensating
- C. Corrective
- D. Preventive

Answer: D

215. Which of the following techniques can be used to sanitize the data contained on a hard drive while allowing for the hard drive to be repurposed?

- A. Degaussing
- B. Drive shredder
- C. Retention platform
- D. Wipe tool

Answer: D

216. After creating a contract for IT contractors, the human resources department changed several clauses. The contract has gone through three revisions. Which of the following processes should the human resources department follow to track revisions?

- A. Version validation
- B. Version changes
- C. Version updates
- D. Version control

Answer: D

217. A company is aware of a given security risk related to a specific market segment. The business chooses not to accept responsibility and target their services to a different market segment. Which of the following describes this risk management strategy?

- A. Exemption
- B. Exception



- C. Avoid
- D. Transfer

Answer: C

218. Which of the following is the most relevant reason a DPO would develop a data inventory?

- A. To manage data storage requirements better
- B. To determine the impact in the event of a breach
- C. To extend the length of time data can be retained
- D. To automate the reduction of duplicated data

Answer: B

219. After a company was compromised, customers initiated a lawsuit. The company's attorneys have requested that the security team initiate a legal hold in response to the lawsuit. Which of the following describes the action the security team will most likely be required to take?

- A. Retain the emails between the security team and affected customers for 30 days.
- B. Retain any communications related to the security breach until further notice.
- C. Retain any communications between security members during the breach response.
- D. Retain all emails from the company to affected customers for an indefinite period of time.

Answer: B

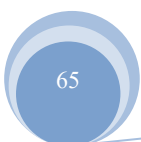
220. Which of the following can be used to compromise a system that is running an RTOS?

- A. Cross-site scripting
- B. Memory injection
- C. Replay attack
- D. Ransomware

Answer: B

221. Which of the following describes the reason for using an MDM solution to prevent jailbreaking?

- A. To secure end-of-life devices from incompatible firmware updates
- B. To avoid hypervisor attacks through VM escape





- C. To eliminate buffer overflows at the application layer
- D. To prevent users from changing the OS of mobile devices

Answer: D

222. A human resources (HR) employee working from home leaves their company laptop open on the kitchen table. A family member walking through the kitchen reads an email from the Chief Financial Officer addressed to the HR department. The email contains information referencing company layoffs. The family member posts the content of the email to social media. Which of the following policies will the HR employee most likely need to review after this incident?

- A. Hybrid work environment
- B. Operations security
- C. Data loss prevention
- D. Social engineering

Answer: B

223. A company plans to secure its systems by:

Preventing users from sending sensitive data over corporate email
Restricting access to potentially harmful websites

Which of the following features should the company set up? (Select two).

- A. DLP software
- B. DNS filtering
- C. File integrity monitoring
- D. Stateful firewall

Answer: B

224. During a SQL update of a database, a temporary field that was created was replaced by an attacker in order to allow access to the system. Which of the following best describes this type of vulnerability?

- A. Race condition
- B. Memory injection
- C. Malicious update





D. Side loading

Answer: A

225. An IT manager is increasing the security capabilities of an organization after a data classification initiative determined that sensitive data could be exfiltrated from the environment. Which of the following solutions would mitigate the risk?

A. XDR

B. SPF

C. DLP

D. DMARC

Answer: C

226. A security manager created new documentation to use in response to various types of security incidents. Which of the following is the next step the manager should take?

A. Set the maximum data retention policy.

B. Securely store the documents on an air-gapped network.

C. Review the documents' data classification policy.

D. Conduct a tabletop exercise with the team.

Answer: D

227. An organization needs to monitor its users' activities to prevent insider threats. Which of the following solutions would help the organization achieve this goal?

A. Behavioral analytics

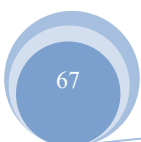
B. Access control lists

C. Identity and access management

D. Network intrusion detection system

Answer: A

228. An administrator is creating a secure method for a contractor to access a test environment. Which of the following would provide the contractor with the best access to the test environment?





- A. Application server
- B. Jump server
- C. RDP server
- D. Proxy server

Answer: B

229. Employees in the research and development business unit receive extensive training to ensure they understand how to best protect company data. Which of the following is the type of data these employees are most likely to use in day-to-day work activities?

- A. Encrypted
- B. Intellectual property
- C. Critical
- D. Data in transit

Answer: B

230. Which of the following describes the maximum allowance of accepted risk?

- A. Risk indicator
- B. Risk level
- C. Risk score
- D. Risk threshold

Answer: D

231. Which of the following metrics impacts the backup schedule as part of the BIA?

- A. RTO
- B. RPO
- C. MTTR
- D. MTBF

Answer: B

232. An employee from the accounting department logs in to the website used for processing the



company's payments. After logging in, a new desktop application automatically downloads on the employee's computer and causes the computer to restart. Which of the following attacks has occurred?

- A. XSS
- B. Watering hole
- C. Typosquatting
- D. Buffer overflow

Answer: B

233. A network administrator wants to ensure that network traffic is highly secure while in transit. Which of the following actions best describes the actions the network administrator should take?

- A. Ensure that NAC is enforced on all network segments, and confirm that firewalls have updated policies to block unauthorized traffic.
- B. Ensure only TLS and other encrypted protocols are selected for use on the network, and only permit authorized traffic via secure protocols.
- C. Configure the perimeter IPS to block inbound HTTPS directory traversal traffic, and verify that signatures are updated on a daily basis.
- D. Ensure the EDR software monitors for unauthorized applications that could be used by threat actors, and configure alerts for the security team.

Answer: B

234. Which of the following most securely protects data at rest?

- A. TLS 1.2
- B. AES-256
- C. Masking
- D. Salting

Answer: B

235. Which of the following alert types is the most likely to be ignored over time?

- A. True positive
- B. True negative



- C. False positive
- D. False negative

Answer: C

236. Which of the following is an algorithm performed to verify that data has not been modified?

- A. Hash
- B. Code check
- C. Encryption
- D. Checksum

Answer: A

237. A company is utilizing an offshore team to help support the finance department. The company wants to keep the data secure by keeping it on a company device but does not want to provide equipment to the offshore team. Which of the following should the company implement to meet this requirement?

- A. VDI
- B. MDM
- C. VPN
- D. VPC

Answer: A

238. An administrator implements web-filtering products but still sees that users are visiting malicious links. Which of the following configuration items does the security administrator need to review?

- A. Intrusion prevention system
- B. Content categorization
- C. Encryption
- D. DNS service

Answer: B

239. A growing organization, which hosts an externally accessible application, adds multiple virtual servers to improve application performance and decrease the resource usage on individual servers. Which of the



following solutions is the organization most likely to employ to further increase performance and availability?

- A. Load balancer
- B. Jump server
- C. Proxy server
- D. SD-WAN

Answer: A

240. Which of the following actions must an organization take to comply with a person's request for the right to be forgotten?

- A. Purge all personally identifiable attributes.
- B. Encrypt all of the data.
- C. Remove all of the person's data.
- D. Obfuscate all of the person's data.

Answer: C

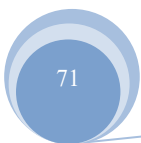
241. An organization has recently decided to implement SSO. The requirements are to leverage access tokens and focus on application authorization rather than user authentication. Which of the following solutions would the engineering team most likely configure?

- A. LDAP
- B. Federation
- C. SAML
- D. OAuth

Answer: D

242. A company is implementing a vendor's security tool in the cloud. The security director does not want to manage users and passwords specific to this tool but would rather utilize the company's standard user directory. Which of the following should the company implement?

- A. 802.1X
- B. SAML





C. RADIUS

D. CHAP

Answer: B

243. A company prevented direct access from the database administrators' workstations to the network segment that contains database servers. Which of the following should a database administrator use to access the database servers?

A. Jump server

B. RADIUS

C. HSM

D. Load balancer

Answer: A

244. A network engineer is increasing the overall security of network devices and needs to harden the devices. Which of the following will best accomplish this task?

A. Configuring centralized logging

B. Generating local administrator accounts

C. Replacing Telnet with SSH

D. Enabling HTTP administration

Answer: C

245. Which of the following are the best for hardening end-user devices? (Selecttwo)

A. Full disk encryption

B. Group-level permissions

C. Account lockout

D. Endpoint protection

E. Proxy server

F. Segmentation

Answer: A,D

246. A company is in the process of migrating to cloud-based services. The company's IT department has limited resources for migration and ongoing support. Which of the following best meets the company's needs?

- A. IPS
- B. WAF
- C. SASE
- D. IAM

Answer: C

247. Which of the following is used to add extra complexity before using a one-way data transformation algorithm?

- A. Key stretching
- B. Data masking
- C. Steganography
- D. Salting

Answer: D

248. Which of the following is required for an organization to properly manage its restore process in the event of system failure?

- A. IRP
- B. DRP
- C. RPO
- D. SDLC

Answer: B

249. The private key for a website was stolen, and a new certificate has been issued. Which of the following needs to be updated next?

- A. SCEP
- B. CRL
- C. OCSP



D. CSR

Answer: B

250. An attacker used XSS to compromise a web server. Which of the following solutions could have been used to prevent this attack?

A. NGFW

B. UTM

C. WAF

D. NAC

Answer: C

251. Which of the following is a prerequisite for a DLP solution?

A. Data destruction

B. Data sanitization

C. Data classification

D. Data masking

Answer: C

252. A technician is opening ports on a firewall for a new system being deployed and supported by a SaaS provider. Which of the following is a risk in the new system?

A. Default credentials

B. Non-segmented network

C. Supply chain vendor

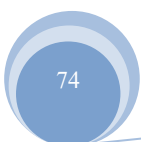
D. Vulnerable software

Answer: C

253. The executive management team is mandating the company develop a disaster recovery plan. The cost must be kept to a minimum, and the money to fund additional internet connections is not available.

Which of the following would be the best option?

A. Hot site





- B. Cold site
- C. Failover site
- D. Warm site

Answer: B

254. Which of the following tools can assist with detecting an employee who has accidentally emailed a file containing a customer's PII?

- A. SCAP
- B. Net Flow
- C. Antivirus
- D. DLP

Answer: D

255. Which of the following is a social engineering attack in which a bad actor impersonates a web URL?

- A. Pretexting
- B. Misinformation
- C. Typosquatting
- D. Watering-hole

Answer: C

256. Which of the following explains why an attacker cannot easily decrypt passwords using a rainbow table attack?

- A. Digital signatures
- B. Salting
- C. Hashing
- D. Perfect forward secrecy

Answer: B

257. A systems administrator discovers a system that is no longer receiving support from the vendor. However, this system and its environment are critical to running the business, cannot be modified, and



must stay online. Which of the following risk treatments is the most appropriate in this situation?

- A. Refect
- B. Accept
- C. Transfer
- D. Avoid

Answer: C

258. An organization would like to calculate the time needed to resolve a hardware issue with a server.

Which of the following risk management processes describes this example?

- A. Recovery point objective
- B. Mean time between failures
- C. Recovery time objective
- D. Mean time to repair

Answer: D

259. A new security regulation was announced that will take effect in the coming year. A company must comply with it to remain in business. Which of the following activities should the company perform next?

- A. Gap analysis
- B. Policy review
- C. Security procedure evaluation
- D. Threat scope reduction

Answer: A

260. A security analyst is reviewing logs to identify the destination of command-and-control traffic originating from a compromised device within the on-premises network. Which of the following is the best log to review?

- A. IDS
- B. Antivirus
- C. Firewall
- D. Application



Answer: D

261. Which of the following vulnerabilities is associated with installing software outside of a manufacturer's approved software repository?

- A. Jailbreaking
- B. Memory injection
- C. Resource reuse
- D. Side loading

Answer: D

262. A newly appointed board member with cybersecurity knowledge wants the board of directors to receive a quarterly report detailing the number of incidents that impacted the organization. The systems administrator is creating a way to present the data to the board of directors. Which of the following should the systems administrator use?

- A. Packet captures
- B. Vulnerability scans
- C. Metadata
- D. Dashboard

Answer: D

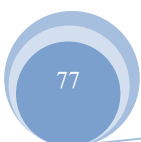
263. A new employee accessed an unauthorized website. An investigation found that the employee violated the company's rules. Which of the following did the employee violate?

- A. MOU
- B. AUP
- C. NDA
- D. MOA

Answer: B

264. Which of the following is a benefit of an RTO when conducting a business impact analysis?

- A. It determines the likelihood of an incident and its cost.





- B. It determines the roles and responsibilities for incident responders.
- C. It determines the state that systems should be restored to following an incident.
- D. It determines how long an organization can tolerate downtime after an incident.

Answer: D

265. Client files can only be accessed by employees who need to know the information and have specified roles in the company. Which of the following best describes this security concept?

- A. Availability
- B. Confidentiality
- C. Integrity
- D. Non-repudiation

Answer: B

266. A security analyst learns that an attack vector, used as part of a recent incident, was a well-known IoT device exploit. The analyst needs to review logs to identify the time of the initial exploit. Which of the following logs should the analyst review first?

- A. Endpoint
- B. Application
- C. Firewall
- D. NAC

Answer: A

267. While conducting a business continuity tabletop exercise, the security team becomes concerned by potential impacts if a generator fails during failover. Which of the following is the team most likely to consider in regard to risk management activities?

- A. RPO
- B. ARO
- C. BIA
- D. MTTR

Answer: D



268. A legal department must maintain a backup from all devices that have been shredded and recycled by a third party. Which of the following best describes this requirement?

- A. Data retention
- B. Certification
- C. Sanitation
- D. Destruction

Answer: A

269. A security engineer is implementing FDE for all laptops in an organization. Which of the following are the most important for the engineer to consider as part of the planning process? (Select two).

- A. Key escrow
- B. TPM presence
- C. Digital signatures
- D. Data tokenization
- E. Public key management
- F. Certificate authority linking

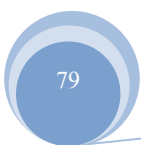
Answer: A,B

270. A systems administrator is changing the password policy within an enterprise environment and wants this update implemented on all systems as quickly as possible. Which of the following operating system security measures will the administrator most likely use?

- A. Deploying PowerShell scripts
- B. Pushing GPO update
- C. Enabling PAP
- D. Updating EDR profiles

Answer: B

271. After a security awareness training session, a user called the IT help desk and reported a suspicious call. The suspicious caller stated that the Chief Financial Officer wanted credit card information in order to





close an invoice. Which of the following topics did the user recognize from the training?

- A. Insider threat
- B. Email phishing
- C. Social engineering
- D. Executive whaling

Answer: C

272. Which of the following examples would be best mitigated by input sanitization?

- A. `<script>alert ("Warning!") ,-</script>`
- B. `nmap - 10.11.1.130`
- C. Email message: "Click this link to get your free gift card."
- D. Browser message: "Your connection is not private."

Answer: A

273. Which of the following is the main consideration when a legacy system that is a critical part of a company's infrastructure cannot be replaced?

- A. Resource provisioning
- B. Cost
- C. Single point of failure
- D. Complexity

Answer: C

274. Which of the following is a reason why a forensic specialist would create a plan to preserve data after an incident and prioritize the sequence for performing forensic analysis?

- A. Order of volatility
- B. Preservation of event logs
- C. Chain of custody
- D. Compliance with legal hold

Answer: A



275. Which of the following security concepts is being followed when implementing a product that offers protection against DDoS attacks?

- A. Availability
- B. Non-repudiation
- C. Integrity
- D. Confidentiality

Answer: C

276. Which of the following threat actors would most likely deface the website of a high-profile music group?

- A. Unskilled attacker
- B. Organized crime
- C. Nation-state
- D. Insider threat

Answer: A

277. To which of the following security categories does an EDR solution belong?

- A. Physical
- B. Operational
- C. Managerial
- D. Technical

Answer: D

278. Which of the following hardening techniques must be applied on a container image before deploying it to a production environment? (Select two).

- A. Remove default applications.
- B. Install a NIPS.
- C. Disable Telnet.
- D. Reconfigure the DNS
- E. Add an SFTP server.



F. Delete the public certificate.

Answer: A,C

279. A security analyst needs to improve the company's authentication policy following a password audit.

Which of the following should be included in the policy? (Select two).

- A. Length
- B. Complexity
- C. Least privilege
- D. Something you have
- E. Security keys
- F. Biometrics

Answer: A,B

280. An organization wants a third-party vendor to do a penetration test that targets a specific device. The organization has provided basic information about the device. Which of the following best describes this kind of penetration test?

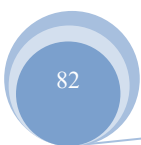
- A. Partially known environment
- B. Unknown environment
- C. Integrated
- D. Known environment

Answer: A

281. An engineer has ensured that the switches are using the latest OS, the servers have the latest patches, and the endpoints' definitions are up to date. Which of the following will these actions most effectively prevent?

- A. Zero-day attacks
- B. Insider threats
- C. End-of-life support
- D. Known exploits

Answer: D





282. Which of the following is a primary security concern for a company setting up a BYOD program?

- A. End of life
- B. Buffer overflow
- C. VM escape
- D. Jailbreaking

Answer: D

283. An organization wants to limit potential impact to its log-in database in the event of a breach. Which of the following options is the security team most likely to recommend?

- A. Tokenization
- B. Hashing
- C. Obfuscation
- D. Segmentation

Answer: B

284. Which of the following control types involves restricting IP connectivity to a router's web management interface to protect it from being exploited by a vulnerability?

- A. Corrective
- B. Physical
- C. Preventive
- D. Managerial

Answer: C

285. A security administrator observed the following in a web server log while investigating an incident:

```
"GET ../../../../etc/passwd"
```

Which of the following attacks did the security administrator most likely see?

- A. Privilege escalation
- B. Credential replay



- C. Brute force
- D. Directory traversal

Answer: D

286. Which of the following data recovery strategies will result in a quick recovery at low cost?

- A. Hot
- B. Cold
- C. Manual
- D. Warm

Answer: D

287. An employee decides to collect PII data from the company's system for personal use. The employee compresses the data into a single encrypted file before sending the file to their personal email. The security department becomes aware of the attempted misuse and blocks the attachment from leaving the corporate environment. Which of the following types of employee training would most likely reduce the occurrence of this type of issue?

(Select two).

- A. Privacy legislation
- B. Social engineering
- C. Risk management
- D. Company compliance
- E. Phishing
- F. Remote work

Answer: A,D

288. Which of the following is a type of vulnerability that may result from outdated algorithms or keys?

- A. Hash collision
- B. Cryptographic
- C. Buffer overflow
- D. Input validation



Answer: B

289. Which of the following should a security team do first before a new web server goes live?

- A. Harden the virtual host.
- B. Create WAF rules.
- C. Enable network intrusion detection.
- D. Apply patch management

Answer: D

290. Which of the following threat vectors is most commonly utilized by insider threat actors attempting data exfiltration?

- A. Unidentified removable devices
- B. Default network device credentials
- C. Spear phishing emails
- D. Impersonation of business units through typosquatting

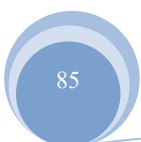
Answer: A

291. A new employee logs in to the email system for the first time and notices a message from human resources about onboarding. The employee hovers over a few of the links within the email and discovers that the links do not correspond to links associated with the company. Which of the following attack vectors is most likely being used?

- A. Business email
- B. Social engineering
- C. Unsecured network
- D. Default credentials

Answer: B

292. A business needs a recovery site but does not require immediate failover. The business also wants to reduce the workload required to recover from an outage. Which of the following recovery sites is the best option?





- A. Hot
- B. Cold
- C. Warm
- D. Geographically dispersed

Answer: C

293. An employee clicked a link in an email from a payment website that asked the employee to update contact information. The employee entered the log-in information but received a “page not found” error message. Which of the following types of social engineering attacks occurred?

- A. Brand impersonation
- B. Pretexting
- C. Typosquatting
- D. Phishing

Answer: D

294. A newly identified network access vulnerability has been found in the OS of legacy IoT devices. Which of the following would best mitigate this vulnerability quickly?

- A. Insurance
- B. Patching
- C. Segmentation
- D. Replacement

Answer: C

295. A company is using a legacy FTP server to transfer financial data to a third party. The legacy system does not support SFTP, so a compensating control is needed to protect the sensitive, financial data in transit. Which of the following would be the most appropriate for the company to use?

- A. Telnet connection
- B. SSH tunneling
- C. Patch installation
- D. Full disk encryption



Answer: B

296. A company is working with a vendor to perform a penetration test Which of the following includes an estimate about the number of hours required to complete the engagement?

- A. SOW
- B. BPA
- C. SLA
- D. NDA

Answer: A

297. Which of the following elements of digital forensics should a company use If It needs to ensure the integrity of evidence?

- A. Preservation
- B. E-discovery
- C. Acquisition
- D. Containment

Answer: A

298. Which of the following cryptographic solutions protects data at rest?

- A. Digital signatures
- B. Full disk encryption
- C. Private key
- D. Steganography

Answer: B

299. Which of the following control types is AUP an example of?

- A. Physical
- B. Managerial
- C. Technical
- D. Operational



Answer: B

300. A technician wants to improve the situational and environmental awareness of existing users as they transition from remote to in-office work. Which of the following is the best option?

- A. Send out periodic security reminders.
- B. Update the content of new hire documentation.
- C. Modify the content of recurring training.
- D. Implement a phishing campaign

Answer: C

301. An administrator has configured a quarantine subnet for all guest devices that connect to the network. Which of the following would be best for the security team to configure on the MDM before allowing access to corporate resources?

- A. Device fingerprinting
- B. Compliance attestation
- C. NAC
- D. 802.1X

Answer: B

302. Which of the following describes the category of data that is most impacted when it is lost?

- A. Confidential
- B. Public
- C. Private
- D. Critical

Answer: D

303. A company wants to update its disaster recovery plan to include a dedicated location for immediate continued operations if a catastrophic event occurs. Which of the following options is best to include in the disaster recovery plan?

- A. Hot site



- B. Warm site
- C. Geolocation
- D. Cold site

Answer: A

304. A Chief Information Security Officer (CISO) has developed information security policies that relate to the software development methodology. Which of the following would the CISO most likely include in the organization's documentation?

- A. Peer review requirements
- B. Multifactor authentication
- C. Branch protection tests
- D. Secrets management configurations

Answer: A

305. Which of the following is used to protect a computer from viruses, malware, and Trojans being installed and moving laterally across the network?

- A. IDS
- B. ACL
- C. EDR
- D. NAC

Answer: C

306. A security analyst is reviewing the security of a SaaS application that the company intends to purchase. Which of the following documentations should the security analyst request from the SaaS application vendor?

- A. Service-level agreement
- B. Third-party audit
- C. Statement of work
- D. Data privacy agreement

Answer: B



307. An employee clicks a malicious link in an email that appears to be from the company's Chief Executive Officer. The employee's computer is infected with ransomware that encrypts the company's files. Which of the following is the most effective way for the company to prevent similar incidents in the future?

- A. Security awareness training
- B. Database encryption
- C. Segmentation
- D. Reporting suspicious emails

Answer: A

308. An employee from the accounting department logs in to a website. A desktop application automatically downloads on the employee's computer. Which of the following has occurred?

- A. XSS
- B. Watering hole
- C. Typosquatting
- D. Buffer overflow

Answer: B

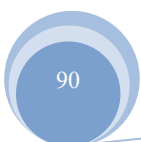
309. Which of the following describes the procedures a penetration tester must follow while conducting a test?

- A. Rules of engagement
- B. Rules of acceptance
- C. Rules of understanding
- D. Rules of execution

Answer: A

310. An organization is building a new backup data center with cost-benefit as the primary requirement and RTO and RPO values around two days. Which of the following types of sites is the best for this scenario?

- A. Real-time recovery
- B. Hot





- C. Cold
- D. Warm

Answer: C

311. An unexpected and out-of-character email message from a Chief Executive Officer's corporate account asked an employee to provide financial information and to change the recipient's contact number. Which of the following attack vectors is most likely being used?

- A. Business email compromise
- B. Phishing
- C. Brand impersonation
- D. Pretexting

Answer: A

312. During a security incident, the security operations team identified sustained network traffic from a malicious IP address: 10.1.4.9. A security analyst is creating an inbound firewall rule to block the IP address from accessing the organization's network. Which of the following fulfills this request?

- A. access-list inbound deny ig source 0.0.0.0/0 destination 10.1.4.9/32
- B. access-list inbound deny ig source 10.1.4.9/32 destination 0.0.0.0/0
- C. access-list inbound permit ig source 10.1.4.9/32 destination 0.0.0.0/0
- D. access-list inbound permit ig source 0.0.0.0/0 destination 10.1.4.9/32

Answer: B

313. Which of the following should be used to ensure a device is inaccessible to a network- connected resource?

- A. Disablement of unused services
- B. Web application firewall
- C. Host isolation
- D. Network-based IDS

Answer: C



314. A company is adding a clause to its AUP that states employees are not allowed to modify the operating system on mobile devices. Which of the following vulnerabilities is the organization addressing?

- A. Cross-site scripting
- B. Buffer overflow
- C. Jailbreaking
- D. Side loading

Answer: C

315. Which of the following is the most likely to be included as an element of communication in a security awareness program?

- A. Reporting phishing attempts or other suspicious activities
- B. Detecting insider threats using anomalous behavior recognition
- C. Verifying information when modifying wire transfer data
- D. Performing social engineering as part of third-party penetration testing

Answer: A

316. A security engineer is installing an IPS to block signature-based attacks in the environment. Which of the following modes will best accomplish this task?

- A. Monitor
- B. Sensor
- C. Audit
- D. Active

Answer: D

317. Which of the following actors attacking an organization is the most likely to be motivated by personal beliefs?

- A. Nation-state
- B. Organized crime
- C. Hacktivist
- D. Insider threat



Answer: C

318. Which of the following enables the use of an input field to run commands that can view or manipulate data?

- A. Cross-site scripting
- B. Side loading
- C. Buffer overflow
- D. SQL injection

Answer: D

319. The security operations center is researching an event concerning a suspicious IP address. A security analyst looks at the following event logs and discovers that a significant portion of the user accounts have experienced failed log-in attempts when authenticating from the same IP address:

```
184.168.131.241 - userA - failed authentication
184.168.131.241 - userA - failed authentication
184.168.131.241 - userB - failed authentication
184.168.131.241 - userB - failed authentication
184.168.131.241 - userC - failed authentication
184.168.131.241 - userC - failed authentication
```

Which of the following most likely describes attack that took place?

- A. Spraying
- B. Brute-force
- C. Dictionary
- D. Rainbow table

Answer: A

320. A security analyst needs to propose a remediation plan for each item in a risk register. The item with the highest priority requires employees to have separate logins for SaaS solutions and different password complexity requirements for each solution. Which of the following implementation plans will most likely resolve this security issue?

- A. Creating a unified password complexity standard
- B. Integrating each SaaS solution with the Identity provider
- C. Securing access to each SaaS by using a single wildcard certificate



D. Configuring geofencing on each SaaS solution

Answer: B

321. A security administrator is deploying a DLP solution to prevent the exfiltration of sensitive customer data. Which of the following should the administrator do first?

- A. Block access to cloud storage websites.
- B. Create a rule to block outgoing email attachments.
- C. Apply classifications to the data.
- D. Remove all user permissions from shares on the file server.

Answer: C

322. A security administrator protects passwords by using hashing. Which of the following best describes what the administrator is doing?

- A. Adding extra characters at the end to increase password length
- B. Generating a token to make the passwords temporal
- C. Using mathematical algorithms to make passwords unique
- D. Creating a rainbow table to protect passwords in a list

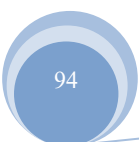
Answer: C

323. As part of new compliance audit requirements, multiple servers need to be segmented on different networks and should be reachable only from authorized internal systems. Which of the following would meet the requirements?

- A. Configure firewall rules to block external access to Internal resources.
- B. Set up a WAP to allow internal access from public networks.
- C. Implement a new IPSec tunnel from internal resources.
- D. Deploy an Internal Jump server to access resources.

Answer: A

324. Which of the following automation use cases would best enhance the security posture of an organization by rapidly updating permissions when employees leave a company?





- A. Provisioning resources
- B. Disabling access
- C. Reviewing change approvals
- D. Escalating permission requests

Answer: B

325. Which of the following activities is included in the post-incident review phase?

- A. Determining the root cause of the incident
- B. Developing steps to mitigate the risks of the incident
- C. Validating the accuracy of the evidence collected during the investigation
- D. Reestablishing the compromised system's configuration and settings

Answer: A

326. After failing an audit twice, an organization has been ordered by a government regulatory agency to pay fines. Which of the following caused this action?

- A. Non-compliance
- B. Contract violations
- C. Government sanctions
- D. Rules of engagement

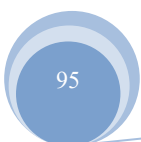
Answer: A

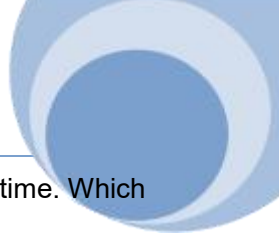
327. Which of the following best describes the concept of information being stored outside of its country of origin while still being subject to the laws and requirements of the country of origin?

- A. Data sovereignty
- B. Geolocation
- C. Intellectual property
- D. Geographic restrictions

Answer: A

328. A customer reports that software the customer downloaded from a public website has malware in it.





However, the company that created the software denies any malware in its software at delivery time. Which of the following techniques will address this concern?

- A. Secure storage
- B. Static code analysis
- C. Input validation
- D. Code signing

Answer: D

329. A security analyst is reviewing the following logs about a suspicious activity alert for a user's VPN log-ins. Which of the following malicious activity indicators triggered the alert?

Log Summary:

User logs in from Chicago, IL multiple times, then suddenly a successful login appears from Rome, Italy, followed again by Chicago logs — all within a short time span.

- A. Impossible travel
- B. Account lockout
- C. Blocked content
- D. Concurrent session usage

Answer: A

330. An attorney prints confidential documents to a copier in an office space near multiple workstations and a reception desk. When the attorney goes to the copier to retrieve the documents, the documents are missing. Which of the following would best prevent this from reoccurring?

- A. Place the copier in the legal department.
- B. Configure DLP on the attorney's workstation.
- C. Set up LDAP authentication on the printer.
- D. Conduct a physical penetration test.

Answer: C

331. A small business uses kiosks on the sales floor to display product information for customers. A security team discovers the kiosks use end-of-life operating systems. Which of the following is the security



team most likely to document as a security implication of the current architecture?

- A. Patch availability
- B. Product software compatibility
- C. Ease of recovery
- D. Cost of replacement

Answer: A

332. A penetration test has demonstrated that domain administrator accounts were vulnerable to pass-the-hash attacks. Which of the following would have been the best strategy to prevent the threat actor from using domain administrator accounts?

- A. Audit each domain administrator account weekly for password compliance.
- B. Implement a privileged access management solution.
- C. Create IDS policies to monitor domain controller access.
- D. Use Group Policy to enforce password expiration.

Answer: B

333. Which of the following is an example of a data protection strategy that uses tokenization?

- A. Encrypting databases containing sensitive data
- B. Replacing sensitive data with surrogate values
- C. Removing sensitive data from production systems
- D. Hashing sensitive data in critical systems

Answer: B

334. A company is planning a disaster recovery site and needs to ensure that a single natural disaster would not result in the complete loss of regulated backup data. Which of the following should the company consider?

- A. Geographic dispersion
- B. Platform diversity
- C. Hot site
- D. Load balancing



Answer: A

335. A bank set up a new server that contains customers' PII. Which of the following should the bank use to make sure the sensitive data is not modified?

- A. Full disk encryption
- B. Network access control
- C. File integrity monitoring
- D. User behavior analytics

Answer: C

336. Which of the following strategies should an organization use to efficiently manage and analyze multiple types of logs?

- A. Deploy a SIEM solution
- B. Create custom scripts to aggregate and analyze logs
- C. Implement EDR technology
- D. Install a unified threat management appliance

Answer: A

337. A security report shows that during a two-week test period, 80% of employees unwittingly disclosed their SSO credentials when accessing an external website. The organization purposely created the website to simulate a cost-free password complexity test. Which of the following would best help reduce the number of visits to similar websites in the future?

- A. Block all outbound traffic from the intranet.
- B. Introduce a campaign to recognize phishing attempts.
- C. Restrict internet access for the employees who disclosed credentials.
- D. Implement a deny list of websites.

Answer: B

338. An organization is developing a security program that conveys the responsibilities associated with the general operation of systems and software within the organization. Which of the following documents would



most likely communicate these expectations?

- A. Business continuity plan
- B. Change management procedure
- C. Acceptable use policy
- D. Software development life cycle policy

Answer: C

339. A company has a website in a server cluster. One server is experiencing very high usage, while others are nearly unused. Which of the following should the company configure to help distribute traffic quickly?

- A. Server multiprocessing
- B. Warm site
- C. Load balancer
- D. Proxy server

Answer: C

340. Which of the following best practices gives administrators a set period to perform changes to an operational system to ensure availability and minimize business impacts?

- A. Impact analysis
- B. Scheduled downtime
- C. Backout plan
- D. Change management boards

Answer: B

341. Which of the following threat actors is the most likely to use large financial resources to attack critical systems located in other countries?

- A. Insider
- B. Unskilled attacker
- C. Nation-state
- D. Hacktivist

Answer: C



342. Which of the following activities are associated with vulnerability management? (Select two).

- A. Reporting
- B. Prioritization
- C. Exploiting
- D. Correlation
- E. Containment
- F. Tabletop exercise

Answer: A,B

343. The Chief Information Officer (CIO) asked a vendor to provide documentation detailing the specific objectives within the compliance framework that the vendor's services meet. The vendor provided a report and a signed letter stating that the services meet 17 of the 21 objectives. Which of the following did the vendor provide to the CIO?

- A. Penetration test results
- B. Self-assessment findings
- C. Attestation of compliance
- D. Third-party audit report

Answer: C

344. HOTSPOT

You are security administrator investigating a potential infection on a network.

Click on each host and firewall. Review all logs to determine which host originated the Infection and then deny each remaining hosts clean or infected.

192.168.10.22

4/17/2019 14:30 Info Scheduled scan initiated

4/17/2019 14:31 Info Checking for update

4/17/2019 14:32 Info No update available

4/17/2019 14:33 Info Checking for definition update

4/17/2019 14:34 Info No definition update available

4/17/2019 14:35 Info Scan type = full

4/17/2019 14:36 Info Scan start

4/17/2019 14:37 Info Scanning system files

4/17/2019 14:38 Info Scanning temporary files

4/17/2019 14:39 Info Scanning services

4/17/2019 14:40 Info Scanning boot sector

4/17/2019 14:41 Info Scan complete

4/17/2019 14:42 Info Files removed: 0

4/17/2019 14:43 Info Files quarantined: 0

4/17/2019 14:44 Info Boot sector: clean

4/17/2019 14:45 Info Next scheduled scan: 4/18/2019 14:30

4/18/2019 2:31 Warn Scheduled scan disabled by process svch0st.exe

4/18/2019 2:32 Warn Scheduled update disabled by process scvh0st.exe

192.168.10.37

4/17/2019 14:30 Info Scheduled scan initiated

4/17/2019 14:31 Info Checking for update

4/17/2019 14:32 Info No update available

4/17/2019 14:33 Info Checking for definition update

4/17/2019 14:34 Info No definition update available

4/17/2019 14:35 Info Scan type = full

4/17/2019 14:36 Info Scan start

4/17/2019 14:37 Info Scanning system files

4/17/2019 14:38 Info Scanning temporary files

4/17/2019 14:39 Info Scanning services

4/17/2019 14:40 Info Scanning boot sector

4/17/2019 14:41 Info Scan complete

4/17/2019 14:42 Info Files removed: 0

4/17/2019 14:43 Info Files quarantined: 0

4/17/2019 14:44 Info Boot sector: clean

4/17/2019 14:45 Info Next scheduled scan: 4/18/2019 14:30

4/18/2019 14:30 Info Scheduled scan initiated

4/18/2019 14:31 Info Checking for update

4/18/2019 14:32 Info No update available

4/18/2019 14:33 Info Checking for definition update

4/18/2019 14:34 Info Update available v10.2.3.4440

4/18/2019 14:33 Info Downloading update

4/18/2019 14:35 Info Definition update complete

4/18/2019 14:35 Info Scan type = full

4/18/2019 14:36 Info Scan start

4/18/2019 14:37 Info Scanning system files

4/18/2019 14:37 Warn File found svch0st.exe match definition v10.2.3.4440

4/18/2019 14:37 Warn File quarantined svch0st.exe

4/18/2019 14:38 Info Scanning temporary files

4/18/2019 14:38 Info Scanning services

NAME: _____

10.10.9.12

4/17/2019 14:30 Info Scheduled scan initiated

4/17/2019 14:31 Info Checking for update

4/17/2019 14:32 Info No update available

4/17/2019 14:33 Info Checking for definition update

4/17/2019 14:34 Info No definition update available

4/17/2019 14:35 Info Scan type = full

4/17/2019 14:36 Info Scan start

4/17/2019 14:37 Info Scanning system files

4/17/2019 14:38 Info Scanning temporary files

4/17/2019 14:39 Info Scanning services

4/17/2019 14:40 Info Scanning boot sector

4/17/2019 14:41 Info Scan complete

4/17/2019 14:42 Info Files removed: 0

4/17/2019 14:43 Info Files quarantined: 0

4/17/2019 14:44 Info Boot sector: clean

4/17/2019 14:45 Info Next scheduled scan: 4/18/2019 14:30

4/18/2019 14:30 Info Scheduled scan initiated

4/18/2019 14:31 Info Checking for update

4/18/2019 14:32 Info No update available

4/18/2019 14:33 Info Checking for definition update

4/18/2019 14:34 Info Update available v10.2.3.4440

4/18/2019 14:33 Info Downloading update

4/18/2019 14:35 Info Definition update complete

4/18/2019 14:35 Info Scan type = full

4/18/2019 14:36 Info Scan start

4/18/2019 14:37 Info Scanning system files

4/18/2019 14:37 Warn File found svch0st.exe match definition v10.2.3.4440

4/18/2019 14:37 Warn File quarantined svch0st.exe

4/18/2019 14:38 Info Scanning temporary files

4/18/2019 14:39 Info Scanning services

4/18/2019 14:40 Info Scanning boot sector

4/18/2019 14:41 Info Scan complete

4/18/2019 14:42 Info Files removed: 0

4/18/2019 14:43 Info Files quarantined: 0

4/18/2019 14:44 Info Boot sector: clean

4/18/2019 14:45 Info Next scheduled scan: 4/19/2019 14:30

10.10.9.18

4/17/2019 14:30 Info Scheduled scan initiated

4/17/2019 14:31 Info Checking for update

4/17/2019 14:32 Info No update available

4/17/2019 14:33 Info Checking for definition update

4/17/2019 14:34 Info No definition update available

4/17/2019 14:35 Info Scan type = full

4/17/2019 14:36 Info Scan start

4/17/2019 14:37 Info Scanning system files

4/17/2019 14:38 Info Scanning temporary files

4/17/2019 14:39 Info Scanning services

4/17/2019 14:40 Info Scanning boot sector

4/17/2019 14:41 Info Scan complete

4/17/2019 14:42 Info Files removed: 0

4/17/2019 14:43 Info Files quarantined: 0

4/17/2019 14:44 Info Boot sector: clean

4/17/2019 14:45 Info Next scheduled scan: 4/18/2019 14:30

4/18/2019 14:30 Info Scheduled scan initiated

4/18/2019 14:31 Info Checking for update

4/18/2019 14:32 Info No update available

4/18/2019 14:33 Info Checking for definition update

4/18/2019 14:34 Error Unable to reach update server

4/18/2019 14:35 Info Scan type = full

4/18/2019 14:36 Info Scan start

4/18/2019 14:37 Info Scanning system files

4/18/2019 14:37 Warn File svch0st.exe match heuristic pattern @c09488c08d0f3k

4/18/2019 14:37 Error Unable to quarantine file svch0st.exe

4/18/2019 14:38 Info Scanning temporary files

4/18/2019 14:39 Info Scanning services

4/18/2019 14:40 Info Scanning boot sector

4/18/2019 14:41 Info Scan complete

4/18/2019 14:42 Info Files removed: 0

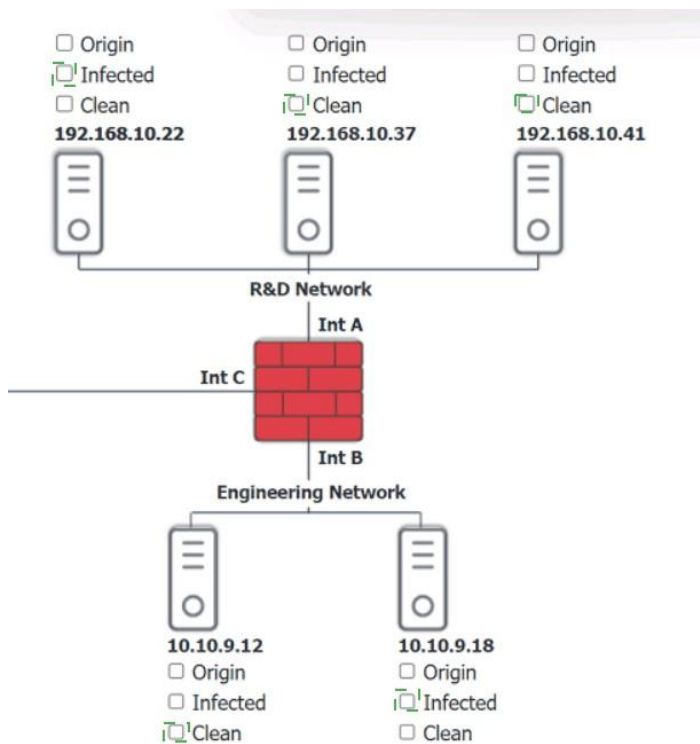
4/18/2019 14:43 Info Files quarantined: 0

4/18/2019 14:44 Info Boot sector: clean

4/18/2019 14:45 Info Next scheduled scan: 4/19/2019 14:30



Answer:



345. A company is changing its mobile device policy. The company has the following requirements:

Company-owned devices Ability to harden the devices Reduced security risk

Compatibility with company resources

Which of the following would best meet these requirements?



- A. BYOD
- B. CYOD
- C. COPE
- D. COBO

Answer: C

346. According to various privacy rules and regulations, users have the power to request that all data pertaining to them is deleted. This is known as:

- A. Right to be forgotten
- B. Attestation and acknowledgement
- C. Data retention
- D. Information deletion

Answer: A

347. An administrator notices that several users are logging in from suspicious IP addresses. After speaking with the users, the administrator determines that the employees were not logging in from those IP addresses and resets the affected users' passwords. Which of the following should the administrator implement to prevent this type of attack from succeeding in the future?

- A. Multifactor authentication
- B. Permissions assignment
- C. Access management
- D. Password complexity

Answer: A

348. Which of the following describes the process of concealing code or text inside a graphical image?

- A. Symmetric encryption
- B. Hashing
- C. Data masking
- D. Steganography

Answer: D



349. A systems administrator needs to encrypt all data on employee laptops. Which of the following encryption levels should be implemented?

- A. Volume
- B. Partition
- C. Full disk
- D. File

Answer: C

350. Which of the following is the most likely reason a security analyst would review SIEM logs?

- A. To check for recent password reset attempts
- B. To monitor for potential DDoS attacks
- C. To assess the scope of a privacy breach
- D. To see correlations across multiple hosts

Answer: D

351. Various company stakeholders meet to discuss roles and responsibilities in the event of a security breach that would affect offshore offices. Which of the following is this an example of?

- A. Tabletop exercise
- B. Penetration test
- C. Geographic dispersion
- D. Incident response

Answer: A

352. A user would like to install software and features that are not available with a smartphone's default software. Which of the following would allow the user to install unauthorized software and enable new features?

- A. SOU
- B. Cross-site scripting
- C. Jailbreaking



D. Side loading

Answer: C

353. Which of the following is the most likely benefit of conducting an internal audit?

- A. Findings are reported to shareholders.
- B. Reports are not formal and can be reassigned.
- C. Control gaps are identified for remediation.
- D. The need for external audits is eliminated.

Answer: C

354. A security analyst sees an increase of vulnerabilities on workstations after a deployment of a company group policy. Which of the following vulnerability types will the analyst most likely find on the workstations?

- A. Misconfiguration
- B. Zero-day
- C. Malicious update
- D. Supply chain

Answer: A

355. After a security incident, a systems administrator asks the company to buy a NAC platform. Which of the following attack surfaces is the systems administrator trying to protect?

- A. Bluetooth
- B. Wired
- C. NFC
- D. SCADA

Answer: B

356. A security manager is implementing MFA and patch management. Which of the following would best describe the control type and category? (Select two).

- A. Physical
- B. Managerial



- C. Detective
- D. Administrator
- E. Preventative
- F. Technical

Answer: E,F

357. After reviewing the following vulnerability scanning report:

Server:192.168.14.6

Service: Telnet

Port: 23 Protocol: TCP

Status: Open Severity: High

Vulnerability: Use of an insecure network protocol

A security analyst performs the following test:

```
nmap -p 23 192.168.14.6 --script telnet-encryption PORT STATE SERVICE REASON
```

23/tcp open telnet syn-ack I telnet encryption:

```
| _ Telnet server supports encryption
```

Which of the following would the security analyst conclude for this reported vulnerability?

- A. It is a false positive.
- B. A rescan is required.
- C. It is considered noise.
- D. Compensating controls exist.

Answer: A

358. A security analyst wants to better understand the behavior of users and devices in order to gain visibility into potential malicious activities. The analyst needs a control to detect when actions deviate from a common baseline Which of the following should the analyst use?

- A. Intrusion prevention system
- B. Sandbox
- C. Endpoint detection and response
- D. Antivirus



Answer: C

359. Which of the following security concepts is accomplished when granting access after an individual has logged into a computer network?

- A. Authorization
- B. Identification
- C. Non-repudiation
- D. Authentication

Answer: A

360. A security engineer at a large company needs to enhance IAM to ensure that employees can only access corporate systems during their shifts. Which of the following access controls should the security engineer implement?

- A. Role-based
- B. Time-of-day restrictions
- C. Least privilege
- D. Biometric authentication

Answer: B

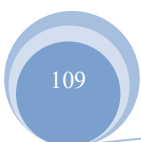
361. Which of the following practices would be best to prevent an insider from introducing malicious code into a company's development process?

- A. Code scanning for vulnerabilities
- B. Open-source component usage
- C. Quality assurance testing
- D. Peer review and approval

Answer: D

362. A company wants to reduce the time and expense associated with code deployment. Which of the following technologies should the company utilize?

- A. Serverless architecture





- B. Thin clients
- C. Private cloud
- D. Virtual machines

Answer: A

363. Which of the following is a reason environmental variables are a concern when reviewing potential system vulnerabilities?

- A. The contents of environmental variables could affect the scope and impact of an exploited vulnerability.
- B. In-memory environmental variable values can be overwritten and used by attackers to insert malicious code.
- C. Environmental variables define cryptographic standards for the system and could create vulnerabilities if deprecated algorithms are used.
- D. Environmental variables will determine when updates are run and could mitigate the likelihood of vulnerability exploitation.

Answer: A

364. A systems administrator is concerned users are accessing emails through a duplicate site that is not run by the company. Which of the following is used in this scenario?

- A. Impersonation
- B. Replication
- C. Phishing
- D. Smishing

Answer: A

365. A security officer is implementing a security awareness program and is placing security- themed posters around the building and is assigning online user training. Which of the following would the security officer most likely implement?

- A. Password policy
- B. Access badges
- C. Phishing campaign



D. Risk assessment

Answer: C

366. The Chief Information Security Officer (CISO) at a large company would like to gain an understanding of how the company's security policies compare to the requirements imposed by external regulators. Which of the following should the CISO use?

- A. Penetration test
- B. Internal audit
- C. Attestation
- D. External examination

Answer: D

367. A security analyst and the management team are reviewing the organizational performance of a recent phishing campaign. The user click-through rate exceeded the acceptable risk threshold, and the management team wants to reduce the impact when a user clicks on a link in a phishing message. Which of the following should the analyst do?

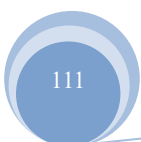
- A. Place posters around the office to raise awareness of common phishing activities.
- B. Implement email security filters to prevent phishing emails from being delivered
- C. Update the EDR policies to block automatic execution of downloaded programs.
- D. Create additional training for users to recognize the signs of phishing attempts.

Answer: C

368. Which of the following makes Infrastructure as Code (IaC) a preferred security architecture over traditional infrastructure models?

- A. Common attacks are less likely to be effective.
- B. Configuration can be better managed and replicated.
- C. Outsourcing to a third party with more expertise in network defense is possible.
- D. Optimization can occur across a number of computing instances.

Answer: B





369. An accounting clerk sent money to an attacker's bank account after receiving fraudulent instructions over the phone to use a new account. Which of the following would most likely prevent this activity in the future?

- A. Standardizing security incident reporting
- B. Executing regular phishing campaigns
- C. Implementing insider threat detection measures
- D. Updating processes for sending wire transfers

Answer: D

370. A security professional discovers a folder containing an employee's personal information on the enterprise's shared drive. Which of the following best describes the data type the security professional should use to identify organizational policies and standards concerning the storage of employees' personal information?

- A. Legal
- B. Financial
- C. Privacy
- D. Intellectual property

Answer: C

371. Which of the following should be used to aggregate log data in order to create alerts and detect anomalous activity?

- A. SIEM
- B. WAF
- C. Network taps
- D. IDS

Answer: A

372. An external security assessment report indicates a high click rate on suspicious emails. The Chief Intelligence Security Officer (CISO) must reduce this behavior. Which of the following should the CISO do first?



- A. Update the acceptable use policy.
- B. Deploy a password management solution.
- C. Issue warning letters to affected users.
- D. Implement a phishing awareness campaign.

Answer: D

373. Which of the following explains how to determine the global regulations that data is subject to regardless of the country where the data is stored?

- A. Geographic dispersion
- B. Data sovereignty
- C. Geographic restrictions
- D. Data segmentation

Answer: B

374. A security team installs an IPS on an organization's network and needs to configure the system to detect and prevent specific network attacks. Which of the following settings should the team configure first within the IPS?

- A. Allow list policies
- B. Packet Inspection
- C. Logging and reporting
- D. Firewall rules

Answer: B

375. Which of the following are cases in which an engineer should recommend the decommissioning of a network device? (Select two).

- A. The device has been moved from a production environment to a test environment.
- B. The device is configured to use cleartext passwords.
- C. The device is moved to an isolated segment on the enterprise network.
- D. The device is moved to a different location in the enterprise.
- E. The device's encryption level cannot meet organizational standards.



F. The device is unable to receive authorized updates.

Answer: E

376. A company has begun labeling all laptops with asset inventory stickers and associating them with employee IDs. Which of the following security benefits do these actions provide? (Choose two.)

- A. If a security incident occurs on the device, the correct employee can be notified.
- B. The security team will be able to send user awareness training to the appropriate device.
- C. Users can be mapped to their devices when configuring software MFA tokens.
- D. User-based firewall policies can be correctly targeted to the appropriate laptops.
- E. When conducting penetration testing, the security team will be able to target the desired laptops.
- F. Company data can be accounted for when the employee leaves the organization.

Answer: A,F

377. Which of the following is the most effective way to protect an application server running software that is no longer supported from network threats?

- A. Air gap
- B. Barricade
- C. Port security
- D. Screen subnet

Answer: A

378. An organization is looking to optimize its environment and reduce the number of patches necessary for operating systems. Which of the following will best help to achieve this objective?

- A. Microservices
- B. Virtualization
- C. Real-time operating system
- D. Containers

Answer: D

379. When trying to access an internal website, an employee reports that a prompt displays, stating that the



site is insecure. Which of the following certificate types is the site most likely using?

- A. Wildcard
- B. Root of trust
- C. Third-party
- D. Self-signed

Answer: D

380. An enterprise security team is researching a new security architecture to better protect the company's networks and applications against the latest cyberthreats. The company has a fully remote workforce. The solution should be highly redundant and enable users to connect to a VPN with an integrated, software-based firewall. Which of the following solutions meets these requirements?

- A. IPS
- B. SIEM
- C. SASE
- D. CASB

Answer: B

381. A company discovers suspicious transactions that were entered into the company's database and attached to a user account that was created as a trap for malicious activity. Which of the following is the user account an example of?

- A. Honeytoken
- B. Honeynet
- C. Honeybot
- D. Honeyfile

Answer: C

382. A security analyst is examining a penetration test report and notices that the tester pivoted to critical internal systems with the same local user ID and password. Which of the following would help prevent this in the future?

- A. Implement centralized authentication with proper password policies



- B. Add password complexity rules and increase password history limits
- C. Connect the systems to an external authentication server
- D. Limit the ability of user accounts to change passwords

Answer: A

383. A security analyst finds a rogue device during a monthly audit of current endpoint assets that are connected to the network. The corporate network utilizes 002.1X for access control. To be allowed on the network, a device must have a Known hardware address, and a valid user name and password must be entered in a captive portal. The following is the audit report:

IP address	MAC	Host	Account
10.18.04.42	BE-AC-11-F1-E4-44	PC-NY	user1
10.18.04.38	EB-AC-11-82-42-F3	PC-CA	user3
10.18.04.59	28-BB-5A-11-52-29	PC-PA	user2
10.18.04.58	28-BB-5A-F0-E9-D1	PC-TX	user4
10.18.04.22	EB-AC-11-82-42-F3	WIN10	user3
10.18.04.26	BB-28-11-21-A2-73	PC-NJ	admin

Which of the following is the most likely way a rogue device was allowed to connect?

- A. A user performed a MAC cloning attack with a personal device.
- B. A DMCP failure caused an incorrect IP address to be distributed
- C. An administrator bypassed the security controls for testing.
- D. DNS hijacking let an attacker intercept the captive portal traffic.

Answer: A

384. A company plans to secure its systems by:

Preventing users from sending sensitive data over corporate email Restricting access to potentially harmful websites

Which of the following features should the company set up? (Select two).

- A. DLP software
- B. DNS filtering
- C. File integrity monitoring
- D. Stateful firewall
- E. Guardralls
- F. Antivirus signatures



Answer: A,B

385. A company purchased cyber insurance to address items listed on the risk register. Which of the following strategies does this represent?

- A. Accept
- B. Transfer
- C. Mitigate
- D. Avoid

Answer: B

386. Which of the following activities is the first stage in the incident response process?

- A. Detection
- B. Declaration
- C. Containment
- D. Vacation

Answer: A

387. Which of the following methods to secure credit card data is best to use when a requirement is to see only the last four numbers on a credit card?

- A. Encryption
- B. Hashing
- C. Masking
- D. Tokenization

Answer: C

388. Which of the following is a common source of unintentional corporate credential leakage in cloud environments?

- A. Code repositories
- B. Dark web
- C. Threat feeds



- D. State actors
- E. Vulnerability databases

Answer: A

389. Which of the following is the most likely motivation for a hacktivist?

- A. Financial gain
- B. Service disruption
- C. Philosophical beliefs
- D. Corporate espionage

Answer: C

390. A legacy device is being decommissioned and is no longer receiving updates or patches. Which of the following describes this scenario?

- A. End of business
- B. End of testing
- C. End of support
- D. End of life

Answer: D

391. A security team is reviewing the findings in a report that was delivered after a third party performed a penetration test. One of the findings indicated that a web application form field is vulnerable to cross-site scripting. Which of the following application security techniques should the security analyst recommend the developer implement to prevent this vulnerability?

- A. Secure cookies
- B. Version control
- C. Input validation
- D. Code signing

Answer: C

392. A spoofed identity was detected for a digital certificate. Which of the following are the type of



unidentified key and the certificate may could be in use on the company domain?

- A. Private key and root certificate
- B. Public key and expired certificate
- C. Private key and self-signed certificate
- D. Public key and wildcard certificate

Answer: C

393. Which of the following would be the best ways to ensure only authorized personnel can access a secure facility? (Select two).

- A. Fencing
- B. Video surveillance
- C. Badge access
- D. Access control vestibule
- E. Sign-in sheet
- F. Sensor

Answer: C,D

394. An administrator must replace an expired SSL certificate. Which of the following does the administrator need to create the new SSL certificate?

- A. CSR
- B. OCSP
- C. Key
- D. CRL

Answer: A

395. A company identified the potential for malicious insiders to harm the organization. Which of the following measures should the organization implement to reduce this risk?

- A. Unified threat management
- B. Web application firewall
- C. User behavior analytics

D. Intrusion detection system

Answer: C

396. SIMULATION

An organization has learned that its data is being exchanged on the dark web. The CIO has requested that you investigate and implement the most secure solution to protect employee accounts.

INSTRUCTIONS

Review the data to identify weak security practices and provide the most appropriate security solution to meet the CIO's requirements.

Identify weak password practices:
(select all that apply)

- ☐ Age
- ☐ Reuse
- ☐ Length
- ☐ Expiration
- ☐ Complexity

Select the containment step that will leave potential evidence on the host uncompromised:

- ☐ PIN code
- ☐ FIDO security key
- ☐ SMS authentication
- ☐ OTP token

Answer:

See the Explanation for complete solution for this task.

Explanation:

MISSING

397. The number of tickets the help desk has been receiving has increased recently due to numerous false-positive phishing reports. Which of the following would be best to help to reduce the false positives?

- A. Performing more phishing simulation campaigns
- B. Improving security awareness training
- C. Hiring more help desk staff
- D. Implementing an incident reporting web page



Answer: B

398. A website user is locked out of an account after clicking an email link and visiting a different website. Web server logs show the user's password was changed, even though the user did not change the password. Which of the following is the most likely cause?

- A. Cross-site request forgery
- B. Directory traversal
- C. ARP poisoning
- D. SQL injection

Answer: A

399. A growing company would like to enhance the ability of its security operations center to detect threats but reduce the amount of manual work required for the security analysts. Which of the following would best enable the reduction in manual work?

- A. SOAR
- B. SIEM
- C. MDM
- D. DLP

Answer: A

400. A financial institution would like to store its customer data in the cloud but still allow the data to be accessed and manipulated while encrypted. Doing so would prevent the cloud service provider from being able to decipher the data due to its sensitivity. The financial institution is not concerned about computational overheads and slow speeds. Which of the following cryptographic techniques would best meet the requirement?

- A. Asymmetric
- B. Symmetric
- C. Homomorphic
- D. Ephemeral

Answer: C



401. A Chief Information Security Officer wants to monitor the company's servers for SQLi attacks and allow for comprehensive investigations if an attack occurs. The company uses SSL decryption to allow traffic monitoring. Which of the following strategies would best accomplish this goal?

- A. Logging all NetFlow traffic into a SIEM
- B. Deploying network traffic sensors on the same subnet as the servers
- C. Logging endpoint and OS-specific security logs
- D. Enabling full packet capture for traffic entering and exiting the servers

Answer: D

402. Which of the following activities uses OSINT?

- A. Social engineering testing
- B. Data analysis of logs
- C. Collecting evidence of malicious activity
- D. Producing IOC for malicious artifacts

Answer: C

403. Which of the following threat actors is the most likely to be hired by a foreign government to attack critical systems located in other countries?

- A. Hacktivist
- B. Whistleblower
- C. Organized crime
- D. Unskilled attacker

Answer: C

404. A systems administrator wants to use a technical solution to explicitly define file permissions for the entire team. Which of the following should the administrator implement?

- A. ACL
- B. Monitoring
- C. Isolation



D. HIPS

Answer: A

405. Which of the following is best used to detect fraud by assigning employees to different roles?

- A. Least privilege
- B. Mandatory vacation
- C. Separation of duties
- D. Job rotation

Answer: D

406. Which of the following allows for the attribution of messages to individuals?

- A. Adaptive identity
- B. Non-repudiation
- C. Authentication
- D. Access logs

Answer: B

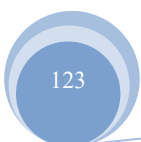
407. A database administrator is updating the company's SQL database, which stores credit card information for pending purchases. Which of the following is the best method to secure the data against a potential breach?

- A. Hashing
- B. Obfuscation
- C. Tokenization
- D. Masking

Answer: C

408. A security team receives reports about high latency and complete network unavailability throughout most of the office building. Flow logs from the campus switches show high traffic on TCP 445. Which of the following is most likely the root cause of this incident?

- A. Buffer overflow





- B. NTP amplification attack
- C. Worm
- D. Kerberoasting attack

Answer: C

409. A systems administrator receives the following alert from a file integrity monitoring tool: The hash of the cmd.exe file has changed.

The systems administrator checks the OS logs and notices that no patches were applied in the last two months. Which of the following most likely occurred?

- A. The end user changed the file permissions.
- B. A cryptographic collision was detected.
- C. A snapshot of the file system was taken.
- D. A rootkit was deployed.

Answer: D

410. A Chief Information Security Officer (CISO) wants to explicitly raise awareness about the increase of ransomware-as-a-service in a report to the management team. Which of the following best describes the threat actor in the CISO's report?

- A. Insider threat
- B. Hacktivist
- C. Nation-state
- D. Organized crime

Answer: D

411. A company is in the process of cutting jobs to manage costs. The Chief Information Security Officer is concerned about the increased risk of an insider threat. Which of the following would most likely help the security awareness team address this potential threat?

- A. Immediately disable the accounts of staff who are likely to be terminated.
- B. Train supervisors to identify and manage disgruntled employees.
- C. Configure DLP to monitor staff who will be terminated.



D. Raise awareness for business leaders on social engineering techniques.

Answer: B

412. Which of the following should a systems administrator use to decrease the company's hardware attack surface?

- A. Replication
- B. Isolation
- C. Centralization
- D. Virtualization

Answer: D

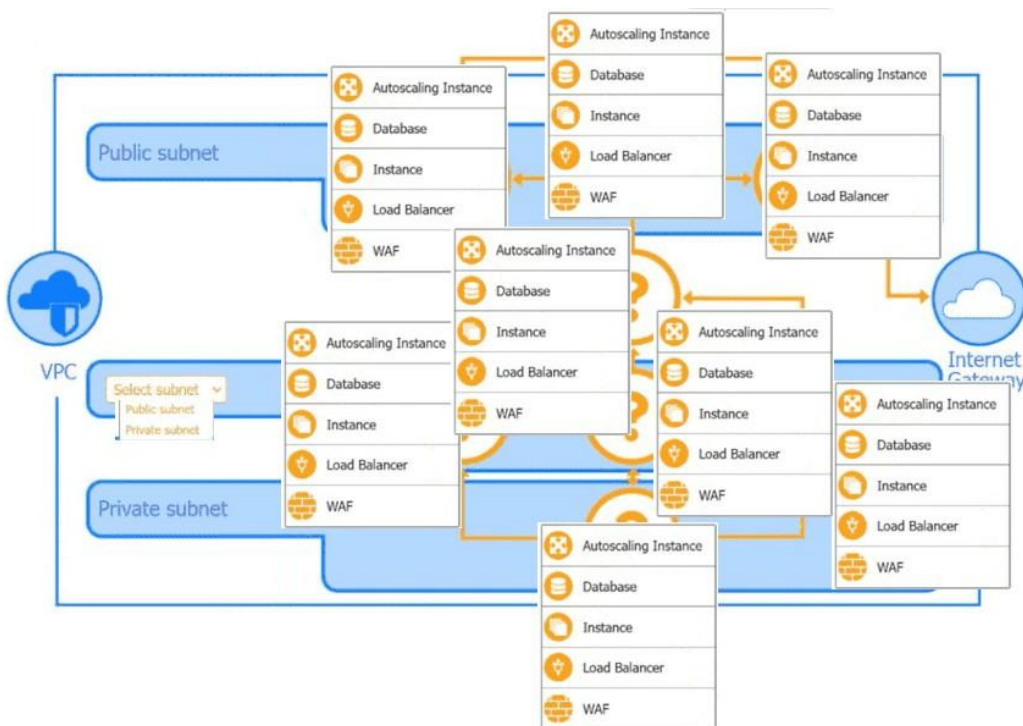
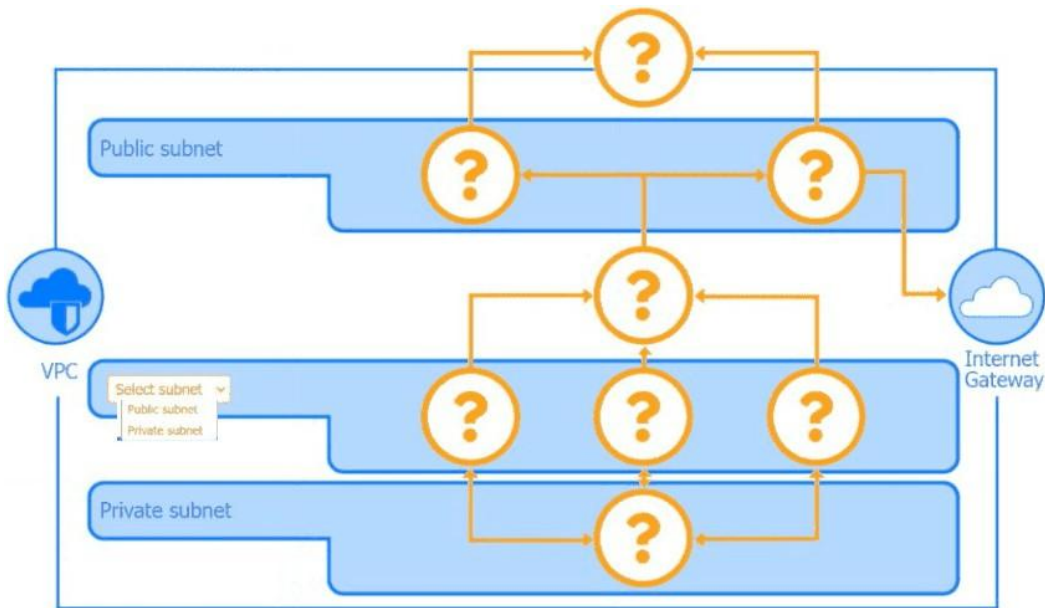
413. Which of the following techniques would attract the attention of a malicious attacker in an insider threat scenario?

- A. Creating a false text file in /docs/salaries
- B. Setting weak passwords in /etc/shadow
- C. Scheduling vulnerable jobs in /etc/crontab
- D. Adding a fake account to /etc/passwd

Answer: A

414. SIMULATION

A security analyst is creating the first draft of a network diagram for the company's new customer-facing payment application that will be hosted by a third-party cloud service provider.



Answer:

See the Explanation for complete solution for this task.

Explanation:



WAF (Web Application Firewall) at the top to handle incoming traffic from the Internet Gateway.

Load Balancer for distributing traffic between instances.

Instances for handling the application workloads, ensuring multiple instances for redundancy.

Autoscaling Instance to adjust the number of instances based on demand dynamically.

In the middle of the diagram, you should select **Private Subnet** in the dropdown menu.

This choice is appropriate because the elements in the lower section, especially the **Database** instances, are part of the private subnet. Placing databases in a private subnet adds an additional layer of security, as it prevents direct internet access to sensitive data. The private subnet is also typically used for backend resources that don't need to be exposed publicly.

At the very top is the WAF. In the public subnet you should have your load balancer(s). Since Load Balancers should be redundant you will place both of them in the public subnet. Below that you will have your scalable instance. Load balancers need IPs and are in subnets which is why this is not the load balancer. In the tier below that, you will need 3 instances in a private subnet At the very bottom, you should have the database.

415. A penetration testing report indicated that an organization should implement controls related to database input validation. Which of the following best identifies the type of vulnerability that was likely discovered during the test?

- A. XSS
- B. Command injection
- C. Buffer overflow
- D. SQLi

Answer: D

416. An analyst discovers a suspicious item in the SQL server logs. Which of the following could be evidence of an attempted SQL injection?

- A. cat /etc/shadow
- B. dig 25.36.99.11
- C. cd .. / .. / .. /
- D. UserId = 10 OR 1=1;

Answer: D

417. A university uses two different cloud solutions for storing student data. Which of the following does this scenario represent?

- A. Load balancing
- B. Parallel processing
- C. Platform diversity
- D. Clustering

Answer: C

418. After an audit, an administrator discovers all users have access to confidential data on a file server. Which of the following should the administrator use to restrict access to the data quickly?

- A. Group Policy
- B. Content filtering
- C. Data loss prevention
- D. Access control lists

Answer: D

419. Which of the following prevents unauthorized modifications to internal processes, assets, and security controls?

- A. Change management
- B. Playbooks
- C. Incident response
- D. Acceptable use policy

Answer: A

420. A company is considering an expansion of access controls for an application that contractors and internal employees use to reduce costs. Which of the following risk elements should the implementation team understand before granting access to the application?

- A. Threshold
- B. Appetite
- C. Tolerance



D. Register

Answer: C

421. A company wants to track modifications to the code used to build new virtual servers. Which of the following will the company most likely deploy?

- A. Change management ticketing system
- B. Behavioral analyzer
- C. Collaboration platform
- D. Version control tool

Answer: D

422. During a penetration test, a vendor attempts to enter an unauthorized area using an access badge. Which of the following types of tests does this represent?

- A. Defensive
- B. Passive
- C. Offensive
- D. Physical

Answer: D

423. A user needs to complete training at <https://comptiatraining.com>. After manually entering the URL, the user sees that the accessed website is noticeably different from the standard company website. Which of the following is the most likely explanation for the difference?

- A. Cross-site scripting
- B. Pretexting
- C. Typosquatting
- D. Vishing

Answer: C

424. Which of the following is a use of CVSS?

- A. To determine the cost associated with patching systems



- B. To identify unused ports and services that should be closed
- C. To analyze code for defects that could be exploited
- D. To prioritize the remediation of vulnerabilities

Answer: D

425. An organization would like to store customer data on a separate part of the network that is not accessible to users on the main corporate network. Which of the following should the administrator use to accomplish this goal?

- A. Segmentation
- B. Isolation
- C. Patching
- D. Encryption

Answer: A

426. Which of the following is a technical security control?

- A. Security guard
- B. Policy
- C. Fence
- D. Firewall

Answer: D

427. Which of the following is the primary purpose of a service that tracks log-ins and time spent using the service?

- A. Availability
- B. Accounting
- C. Authentication
- D. Authorization

Answer: B

428. An engineer needs to ensure that a script has not been modified before it is launched. Which of the



following best provides this functionality?

- A. Masking
- B. Obfuscation
- C. Hashing
- D. Encryption

Answer: C

429. Which of the following is a type of vulnerability that refers to the unauthorized installation of applications on a device through means other than the official application store?

- A. Cross-site scripting
- B. Buffer overflow
- C. Jailbreaking
- D. Side loading

Answer: D

430. Which of the following is a possible consequence of a VM escape?

- A. Malicious instructions can be inserted into memory and give the attacker elevated permissions.
- B. An attacker can access the hypervisor and compromise other VMs.
- C. Unencrypted data can be read by a user in a separate environment.
- D. Users can install software that is not on the manufacturer's approved list.

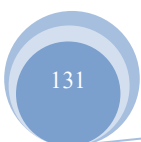
Answer: B

431. Which of the following is a preventive physical security control?

- A. Video surveillance system
- B. Bollards
- C. Alarm system
- D. Motion sensors

Answer: B

432. A company decided to reduce the cost of its annual cyber insurance policy by removing the coverage





for ransomware attacks.

Which of the following analysis elements did the company most likely use in making this decision?

- A. IMTTR
- B. RTO
- C. ARO
- D. MTBF

Answer: C

433. The Chief Information Security Officer wants to put security measures in place to protect PII. The organization needs to use its existing labeling and classification system to accomplish this goal. Which of the following would most likely be configured to meet the requirements?

- A. Tokenization
- B. S/MIME
- C. DLP
- D. MFA

Answer: C

434. A company must ensure sensitive data at rest is rendered unreadable. Which of the following will the company most likely use?

- A. Hashing
- B. Tokenization
- C. Encryption
- D. Segmentation

Answer: C

435. A security operations center determines that the malicious activity detected on a server is normal. Which of the following activities describes the act of ignoring detected activity in the future?

- A. Tuning
- B. Aggregating
- C. Quarantining



D. Archiving

Answer: A

436. A malicious update was distributed to a common software platform and disabled services at many organizations. Which of the following best describes this type of vulnerability?

- A. DDoS attack
- B. Rogue employee
- C. Insider threat
- D. Supply chain

Answer: D

437. Which of the following is the most common data loss path for an air-gapped network?

- A. Bastion host
- B. Unsecured Bluetooth
- C. Unpatched OS
- D. Removable devices

Answer: D

438. A security administrator recently reset local passwords and the following values were recorded in the system:

Host	Account	MD5 password values
ACCT-PC-1	admin	f1bdf5ed1d7ad7ede4e3809bd35644b0
HR-PC-1	admin	d706ab8258fe67c131ebc57a6e28184
IT-PC-2	admin	f8ddb9cbb321d7dfbf6cb059736f0b3d
FILE-SRV-1	admin	f054bbd2f5ebab9cb5571000b2c60c02
DB-SRV-1	admin	8638f732ba7cf2d95b16979e2725da78

Which of the following in the security administrator most likely protecting against?

- A. Account sharing
- B. Weak password complexity
- C. Pass-the-hash attacks
- D. Password compromise

Answer: C



439. A systems administrator is working on a solution with the following requirements:

- Provide a secure zone.
- Enforce a company-wide access control policy.
- Reduce the scope of threats.

Which of the following is the systems administrator setting up?

- A. Zero Trust
- B. AAA
- C. Non-repudiation
- D. CIA

Answer: A

440. A Chief Information Security Officer would like to conduct frequent, detailed reviews of systems and procedures to track compliance objectives. Which of the following is the best method to achieve this objective?

- A. Third-party attestation
- B. Penetration testing
- C. Internal auditing
- D. Vulnerability scans

Answer: C

441. A company is currently utilizing usernames and passwords, and it wants to integrate an MFA method that is seamless, can integrate easily into a user's workflow, and can utilize employee-owned devices.

Which of the following will meet these requirements?

- A. Push notifications
- B. Phone call
- C. Smart card
- D. Offline backup codes

Answer: A



442. Which of the following can be used to mitigate attacks from high-risk regions?

- A. Obfuscation
- B. Data sovereignty
- C. IP geolocation
- D. Encryption

Answer: C

443. Which of the following types of identification methods can be performed on a deployed application during runtime?

- A. Dynamic analysis
- B. Code review
- C. Package monitoring
- D. Bug bounty

Answer: A

444. Which of the following would best prepare a security team for a specific incident response scenario?

- A. Situational awareness
- B. Risk assessment
- C. Root cause analysis
- D. Tabletop exercise

Answer: D

445. Which of the following is the best way to consistently determine on a daily basis whether security settings on servers have been modified?

- A. Automation
- B. Compliance checklist
- C. Attestation
- D. Manual audit

Answer: A



446. A security analyst reviews web server logs and sees the following entries:

* 16.22.48.102 -- 26/April/2023 22:00:04.33 GET "http://www.databaseInfo.com/index.html/*"

200

* 16.22.48.102 -- 26/April/2023 22:00:07.23 GET

"http://www.databaseInfo.com/index.html/.." 404

* 16.22.48.102 -- 26/April/2023 22:01:16.03 GET

"http://www.databaseInfo.com/index.html/./images" 404

* 16.22.48.102 -- 26/April/2023 22:03:10.25 GET

"http://www.databaseInfo.com/index.html/./passwords" 404

* 16.22.48.102 -- 26/April/2023 22:05:11.22 GET

"http://www.databaseInfo.com/index.html/./storedSQLqueries" 404 Which of the following attacks is most likely being attempted?

- A. Denial of service
- B. Password spraying
- C. SQL injection
- D. Directory traversal

Answer: D

447. A company is concerned with supply chain compromise of new servers and wants to limit this risk.

Which of the following should the company review first?

- A. Sanitization procedure
- B. Acquisition process
- C. Change management
- D. Asset tracking

Answer: B

448. Which of the following is the final step of the modern response process?

- A. Lessons learned
- B. Eradication
- C. Containment



D. Recovery

Answer: A

449. A client asked a security company to provide a document outlining the project, the cost, and the completion time frame. Which of the following documents should the company provide to the client?

A. MSA

B. SLA

C. BPA

D. SOW

Answer: D

450. During a recent company safety stand-down, the cyber-awareness team gave a presentation on the importance of cyber hygiene. One topic the team covered was best practices for printing centers. Which of the following describes an attack method that relates to printing centers?

A. Whaling

B. Credential harvesting

C. Prepending

D. Dumpster diving

Answer: D

451. Which of the following is the stage in an investigation when forensic images are obtained?

A. Acquisition

B. Preservation

C. Reporting

D. E-discovery

Answer: A

452. An attacker submits a request containing unexpected characters in an attempt to gain unauthorized access to information within the underlying systems. Which of the following best describes this attack?

A. Side loading



- B. Target of evaluation
- C. Resource reuse
- D. SQL injection

Answer: D

453. A company is considering an expansion of access controls for an application that contractors and internal employees use to reduce costs. Which of the following risk elements should the implementation team understand before granting access to the application?

- A. Threshold
- B. Appetite
- C. Avoidance
- D. Register

Answer: B

454. Which of the following best describes the practice of researching laws and regulations related to information security operations within a specific industry?

- A. Compliance reporting
- B. GDPR
- C. Due diligence
- D. Attestation

Answer: C

455. A new vulnerability enables a type of malware that allows the unauthorized movement of data from a system. Which of the following would detect this behavior?

- A. Implementing encryption
- B. Monitoring outbound traffic
- C. Using default settings
- D. Closing all open ports

Answer: B



456. A security team purchases a tool for cloud security posture management. The team is quickly overwhelmed by the number of misconfigurations that the tool detects. Which of the following should the security team configure to establish workflows for cloud resource security?

- A. CASB
- B. IAM
- C. SOAR
- D. XDR

Answer: C

457. Which of the following agreements defines response time, escalation, and performance metrics?

- A. BPA
- B. MOA
- C. NDA
- D. SLA

Answer: D

458. An administrator was notified that a user logged in remotely after hours and copied large amounts of data to a personal device.

Which of the following best describes the user's activity?

- A. Penetration testing
- B. Phishing campaign
- C. External audit
- D. Insider threat

Answer: D

459. A company has yearly engagements with a service provider. The general terms and conditions are the same for all engagements. The company wants to simplify the process and revisit the general terms every three years. Which of the following documents would provide the best way to set the general terms?

- A. MSA
- B. NDA



C. MOU

D. SLA

Answer: A

460. Which of the following organizational documents is most often used to establish and communicate expectations associated with integrity and ethical behavior within an organization?

A. AUP

B. SLA

C. EULA

D. MOA

Answer: A

461. Which of the following is the best way to remove personal data from a social media account that is no longer being used?

A. Exercise the right to be forgotten

B. Uninstall the social media application

C. Perform a factory reset

D. Terminate the social media account

Answer: A

462. Which of the following is the best way to securely store an encryption key for a data set in a manner that allows multiple entities to access the key when needed?

A. Public key infrastructure

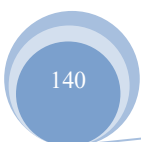
B. Open public ledger

C. Public key encryption

D. Key escrow

Answer: D

463. Which of the following would be the best solution to deploy a low-cost standby site that includes hardware and internet access?





- A. Recovery site
- B. Cold site
- C. Hot site
- D. Warm site

Answer: B

464. Which of the following is the act of proving to a customer that software developers are trained on secure coding?

- A. Assurance
- B. Contract
- C. Due diligence
- D. Attestation

Answer: D

465. Which of the following phases of the incident response process attempts to minimize disruption?

- A. Recovery
- B. Containment
- C. Preparation
- D. Analysis

Answer: B

466. An organization recently started hosting a new service that customers access through a web portal. A security engineer needs to add to the existing security devices a new solution to protect this new service.

Which of the following is the engineer most likely to deploy?

- A. Layer 4 firewall
- B. NGFW
- C. WAF
- D. UTM

Answer: C



467. After a recent ransomware attack on a company's system, an administrator reviewed the log files.

Which of the following control types did the administrator use?

- A. Compensating
- B. Detective
- C. Preventive
- D. Corrective

Answer: B

468. A company's accounts payable clerk receives a message from a vendor asking to change their bank account before paying an invoice. The clerk makes the change and sends the payment to the new account. Days later, the clerk receives another message from the same vendor with a request for a missing payment to the original bank account. Which of the following has most likely occurred?

- A. Phishing campaign
- B. Data exfiltration
- C. Pretext calling
- D. Business email compromise

Answer: D

469. For which of the following reasons would a systems administrator leverage a 3DES hash from an installer file that is posted on a vendor's website?

- A. To test the integrity of the file
- B. To validate the authenticity of the file
- C. To activate the license for the file
- D. To calculate the checksum of the file

Answer: A

470. A security engineer is working to address the growing risks that shadow IT services are introducing to the organization. The organization has taken a cloud-first approach and does not have an on-premises IT infrastructure. Which of the following would best secure the organization?

- A. Upgrading to a next-generation firewall



- B. Deploying an appropriate in-line CASB solution
- C. Conducting user training on software policies
- D. Configuring double key encryption in SaaS platforms

Answer: B

471. Which of the following is the best reason to complete an audit in a banking environment?

- A. Regulatory requirement
- B. Organizational change
- C. Self-assessment requirement
- D. Service-level requirement

Answer: A

472. An IT manager is putting together a documented plan describing how the organization will keep operating in the event of a global incident. Which of the following plans is the IT manager creating?

- A. Business continuity
- B. Physical security
- C. Change management
- D. Disaster recovery

Answer: A

473. A systems administrator is auditing all company servers to ensure they meet the minimum security baseline. While auditing a Linux server, the systems administrator observes the `/etc/shadow` file has permissions beyond the baseline recommendation. Which of the following commands should the systems administrator use to resolve this issue?

- A. `chmod`
- B. `grep`
- C. `dd`
- D. `passwd`

Answer: A

474. A security administrator needs a method to secure data in an environment that includes some form of checks so that the administrator can track any changes. Which of the following should the administrator set up to achieve this goal?

- A. SPF
- B. GPO
- C. NAC
- D. FIM

Answer: D

475. A company is developing a critical system for the government and storing project information on a fileshare. Which of the following describes how this data will most likely be classified? (Select two).

- A. Private
- B. Confidential
- C. Public
- D. Operational
- E. Urgent
- F. Restricted

Answer: B,F

476. Which of the following best describe the benefits of a microservices architecture when compared to a monolithic architecture? (Select two).

- A. Easier debugging of the system
- B. Reduced cost of ownership of the system
- C. Improved scalability of the system
- D. Increased compartmentalization of the system
- E. Stronger authentication of the system
- F. Reduced complexity of the system

Answer: C,D

477. A security analyst reviews domain activity logs and notices the following:

```
UserID jsmith, password authentication: succeeded, MFA: failed (invalid code)
UserID jsmith, password authentication: succeeded, MFA: failed (invalid code)
UserID jsmith, password authentication: succeeded, MFA: failed (invalid code)
UserID jsmith, password authentication: succeeded, MFA: failed (invalid code)
```

Which of the following is the best explanation for what the security analyst has discovered?

- A. The user jsmith's account has been locked out.
- B. A keylogger is installed on [smith's workstation
- C. An attacker is attempting to brute force ismith's account.
- D. Ransomware has been deployed in the domain.

Answer: C

478. Which of the following best represents an application that does not have an on-premises requirement and is accessible from anywhere?

- A. Pass
- B. Hybrid cloud
- C. Private cloud
- D. IaaS
- E. SaaS

Answer: E

479. Which of the following teams combines both offensive and defensive testing techniques to protect an organization's critical systems?

- A. Red
- B. Blue
- C. Purple
- D. Yellow

Answer: C

480. A security analyst receives alerts about an internal system sending a large amount of unusual DNS queries to systems on the internet over short periods of time during non- business hours. Which of the following is most likely occurring?

- A. A worm is propagating across the network.



- B. Data is being exfiltrated.
- C. A logic bomb is deleting data.
- D. Ransomware is encrypting files.

Answer: B

481. A company requires hard drives to be securely wiped before sending decommissioned systems to recycling. Which of the following best describes this policy?

- A. Enumeration
- B. Sanitization
- C. Destruction
- D. Inventory

Answer: B

482. Which of the following is most likely associated with introducing vulnerabilities on a corporate network by the deployment of unapproved software?

- A. Hacktivists
- B. Script kiddies
- C. Competitors
- D. Shadow IT

Answer: D

483. Which of the following best describes why the SMS DIP authentication method is more risky to implement than the TOTP method?

- A. The SMS OTP method requires an end user to have an active mobile telephone service and SIM card.
- B. Generally, SMS OTP codes are valid for up to 15 minutes while the TOTP time frame is 30 to 60 seconds
- C. The SMS OTP is more likely to be intercepted and lead to unauthorized disclosure of the code than the TOTP method.
- D. The algorithm used to generate an SMS OTP code is weaker than the one used to generate a TOTP code

Answer: C



484. A security analyst receives an alert from a corporate endpoint used by employees to issue visitor badges. The alert contains the following details:

Which of the following best describes the indicator that triggered the alert?

- A. Blocked content
- B. Brute-force attack
- C. Concurrent session usage
- D. Account lockout

Answer: B

485. Which of the following is the best reason to perform a tabletop exercise?

- A. To address audit findings
- B. To collect remediation response times
- C. To update the IRP
- D. To calculate the ROI

Answer: C

486. An analyst is reviewing an incident in which a user clicked on a link in a phishing email. Which of the following log sources would the analyst utilize to determine whether the connection was successful?

- A. Network
- B. System
- C. Application
- D. Authentication

Answer: A

487. A systems administrator receives an alert that a company's internal file server is very slow and is only working intermittently. The systems administrator reviews the server management software and finds the following information about the server:

ServerName	#Connections	CPU%	MEM%	Read/s	Writes/s
FileSev01	12	99.68	97%	50KB/s	100KB/s



Which of the following indicators most likely triggered this alert?

- A. Concurrent session usage
- B. Network saturation
- C. Account lockout
- D. Resource consumption

Answer: D

488. A business received a small grant to migrate its infrastructure to an off-premises solution. Which of the following should be considered first?

- A. Security of cloud providers
- B. Cost of implementation
- C. Ability of engineers
- D. Security of architecture

Answer: D

489. A systems administrator is creating a script that would save time and prevent human error when performing account creation for a large number of end users. Which of the following would be a good use case for this task?

- A. Off-the-shelf software
- B. Orchestration
- C. Baseline
- D. Policy enforcement

Answer: B

490. An important patch for a critical application has just been released, and a systems administrator is identifying all of the systems requiring the patch. Which of the following must be maintained in order to ensure that all systems requiring the patch are updated?

- A. Asset inventory
- B. Network enumeration
- C. Data certification



D. Procurement process

Answer: A

491. Which of the following allows a systems administrator to tune permissions for a file?

- A. Patching
- B. Access control list
- C. Configuration enforcement
- D. Least privilege

Answer: B

492. A security analyst is evaluating a SaaS application that the human resources department would like to implement. The analyst requests a SOC 2 report from the SaaS vendor. Which of the following processes is the analyst most likely conducting?

- A. Internal audit
- B. Penetration testing
- C. Attestation
- D. Due diligence

Answer: D

493. An administrator is investigating an incident and discovers several users' computers were infected with malware after viewing files that were shared with them. The administrator discovers no degraded performance in the infected machines and an examination of the log files does not show excessive failed logins. Which of the following attacks is most likely the cause of the malware?

- A. Malicious flash drive
- B. Remote access Trojan
- C. Brute-forced password
- D. Cryptojacking

Answer: D

494. A company wants to ensure secure remote access to its internal network. The company has only one

public IP and would like to avoid making any changes to the current network setup. Which of the following solutions would best accomplish this goal?

- A. PAT
- B. IPSec VPN
- C. Perimeter network
- D. Reverse proxy

Answer: B

495. A healthcare organization wants to provide a web application that allows individuals to digitally report health emergencies.

Which of the following is the most important consideration during development?

- A. Scalability
- B. Availability
- C. Cost
- D. Ease of deployment

Answer: B

496. Which of the following provides the details about the terms of a test with a third-party penetration tester?

- A. Rules of engagement
- B. Supply chain analysis
- C. Right to audit clause
- D. Due diligence

Answer: A

497. Which of the following is the best way to provide secure remote access for employees while minimizing the exposure of a company's internal network?

- A. VPN
- B. LDAP
- C. FTP



D. RADIUS

Answer: A

498. Which of the following technologies can achieve microsegmentation?

- A. Next-generation firewalls
- B. Software-defined networking
- C. Embedded systems
- D. Air-gapped

Answer: B

499. An external vendor recently visited a company's headquarters for a presentation. Following the visit a member of the hosting team found a file that the external vendor left behind on a server. The file contained detailed architecture information and code snippets. Which of the following data types best describes this file?

- A. Government
- B. Public
- C. Proprietary
- D. Critical

Answer: C

500. A business provides long-term cold storage services to banks that are required to follow regulator-imposed data retention guidelines. Banks that use these services require that data is disposed of in a specific manner at the conclusion of the regulatory threshold for data retention. Which of the following aspects of data management is the most important to the bank in the destruction of this data?

- A. Encryption
- B. Classification
- C. Certification
- D. Procurement

Answer: B



501. An employee in the accounting department receives an email containing a demand for payment for services performed by a vendor. However, the vendor is not in the vendor management database. Which of the following in this scenario is an example of?

- A. Pretexting
- B. Impersonation
- C. Ransomware
- D. Invoice scam

Answer: D

502. A security audit of an organization revealed that most of the IT staff members have domain administrator credentials and do not change the passwords regularly. Which of the following solutions should the security team propose to resolve the findings in the most complete way?

- A. Creating group policies to enforce password rotation on domain administrator credentials
- B. Reviewing the domain administrator group, removing all unnecessary administrators, and rotating all passwords
- C. Integrating the domain administrator's group with an IdP and requiring SSO with MFA for all access
- D. Securing domain administrator credentials in a PAM vault and controlling access with role-based access control

Answer: D

503. Which of the following can a security director use to prioritize vulnerability patching within a company's IT environment?

- A. SOAR
- B. CVSS
- C. SIEM
- D. CVE

Answer: B

504. Which of the following receives logs from various devices and services, and then presents alerts?

- A. SIEM



- B. SCADA
- C. SNMP
- D. SCAP

Answer: A

505. An IT manager informs the entire help desk staff that only the IT manager and the help desk lead will have access to the administrator console of the help desk software. Which of the following security techniques is the IT manager setting up?

- A. Hardening
- B. Employee monitoring
- C. Configuration enforcement
- D. Least privilege

Answer: D

506. Several employees received a fraudulent text message from someone claiming to be the Chief Executive Officer (CEO). The message stated:

"I'm in an airport right now with no access to email. I need you to buy gift cards for employee recognition awards. Please send the gift cards to following email address."

Which of the following are the best responses to this situation? (Choose two).

- A. Cancel current employee recognition gift cards.
- B. Add a smishing exercise to the annual company training.
- C. Issue a general email warning to the company.
- D. Have the CEO change phone numbers.
- E. Conduct a forensic investigation on the CEO's phone.
- F. Implement mobile device management.

Answer: B,C

507. An administrator needs to perform server hardening before deployment. Which of the following steps should the administrator take? (Select two).

- A. Disable default accounts.



- B. Add the server to the asset inventory.
- C. Remove unnecessary services.
- D. Document default passwords.
- E. Send server logs to the SIEM.
- F. Join the server to the corporate domain.

Answer: A,C

508. Which of the following security measures is required when using a cloud-based platform for IoT management?

- A. Encrypted connection
- B. Federated identity
- C. Firewall
- D. Single sign-on

Answer: A

509. A security analyst learns that an attack vector, which was used as a part of a recent incident, was a well-known IoT device exploit. The analyst needs to review logs to identify the time of initial exploit. Which of the following logs should the analyst review first?

- A. Wireless access point
- B. Switch
- C. Firewall
- D. NAC

Answer: A

510. Several customers want an organization to verify its security controls are operating effectively and have requested an independent opinion. Which of the following is the most efficient way to address these requests?

- A. Hire a vendor to perform a penetration test.
- B. Perform an annual self-assessment.
- C. Allow each client the right to audit.



D. Provide a third-party attestation report.

Answer: D

511. An organization maintains intellectual property that it wants to protect. Which of the following concepts would be most beneficial to add to the company's security awareness training program?

- A. Insider threat detection
- B. Simulated threats
- C. Phishing awareness
- D. Business continuity planning

Answer: A

512. After a recent vulnerability scan, a security engineer needs to harden the routers within the corporate network. Which of the following is the most appropriate to disable?

- A. Console access
- B. Routing protocols
- C. VLANs
- D. Web-based administration

Answer: D

513. Which of the following scenarios describes a possible business email compromise attack?

- A. An employee receives a gift card request in an email that has an executive's name in the display field of the email.
- B. Employees who open an email attachment receive messages demanding payment in order to access files.
- C. A service desk employee receives an email from the HR director asking for log-in credentials to a cloud administrator account.
- D. An employee receives an email with a link to a phishing site that is designed to look like the company's email portal.

Answer: A



514. An IT administrator needs to ensure data retention standards are implemented on an enterprise application. Which of the following describes the administrator's role?

- A. Processor
- B. Custodian
- C. Privacy officer
- D. Owner

Answer: D

515. Various company stakeholders meet to discuss roles and responsibilities in the event of a security breach affecting offshore offices. Which of the following is this an example of?

- A. Tabletop exercise
- B. Penetration test
- C. Geographic dispersion
- D. Incident response

Answer: A

516. A security architect wants to prevent employees from receiving malicious attachments by email. Which of the following functions should the chosen solution do?

- A. Apply IP address reputation data.
- B. Tap and monitor the email feed.
- C. Scan email traffic inline.
- D. Check SPF records.

Answer: C

517. Which of the following would be the most appropriate way to protect data in transit?

- A. SHA-256
- B. SSL 3.0
- C. TLS 1.3
- D. AES-256

Answer: C



518. A visitor plugs a laptop into a network jack in the lobby and is able to connect to the company's network. Which of the following should be configured on the existing network infrastructure to best prevent this activity?

- A. Port security
- B. Web application firewall
- C. Transport layer security
- D. Virtual private network

Answer: A

519. A government worker secretly copies classified files that contain defense tactics information to an external drive. The government worker then gives the external drive to a corrupt organization. Which of the following best describes the motivation of the worker?

- A. Espionage
- B. Data exfiltration
- C. Financial gain
- D. Blackmail

Answer: A

520. A site reliability engineer is designing a recovery strategy that requires quick failover to an identical site if the primary facility goes down. Which of the following types of sites should the engineer consider?

- A. Recovery site
- B. Hot site
- C. Cold site
- D. Warm site

Answer: B

521. Which of the following is the best way to validate the integrity and availability of a disaster recovery site?

- A. Lead a simulated failover.



- B. Conduct a tabletop exercise.
- C. Periodically test the generators.
- D. Develop requirements for database encryption.

Answer: A

522. An employee emailed a new systems administrator a malicious web link and convinced the administrator to change the email server's password. The employee used this access to remove the mailboxes of key personnel. Which of the following security awareness concepts would help prevent this threat in the future?

- A. Recognizing phishing
- B. Providing situational awareness training
- C. Using password management
- D. Reviewing email policies

Answer: A

523. A company is experiencing issues with employees leaving the company for a competitor and taking customer contact information with them. Which of the following tools will help prevent this from reoccurring?

- A. FIM
- B. NAC
- C. IDS
- D. UBA

Answer: D

524. A bank insists all of its vendors must prevent data loss on stolen laptops. Which of the following strategies is the bank requiring?

- A. Encryption at rest
- B. Masking
- C. Data classification
- D. Permission restrictions

Answer: A



525. A university employee logged on to the academic server and attempted to guess the system administrators' log-in credentials. Which of the following security measures should the university have implemented to detect the employee's attempts to gain access to the administrators' accounts?

- A. Two-factor authentication
- B. Firewall
- C. Intrusion prevention system
- D. User activity logs

Answer: D

526. Which of the following is a risk of conducting a vulnerability assessment?

- A. A disruption of business operations
- B. Unauthorized access to the system
- C. Reports of false positives
- D. Finding security gaps in the system

Answer: A

527. A security analyst wants to automate a task that shares data between systems. Which of the following is the best option for the analyst to use?

- A. SOAR
- B. API
- C. SFTP
- D. RDP

Answer: B

528. A company's website is [www. Company. com](http://www.Company.com). Attackers purchased the domain www. company.com. Which of the following types of attacks describes this example?

- A. Typosquatting
- B. Brand Impersonation
- C. On-path



D. Watering-hole

Answer: A

529. A company wants to improve the availability of its application with a solution that requires minimal effort in the event a server needs to be replaced or added. Which of the following would be the best solution to meet these objectives?

- A. Load balancing
- B. Fault tolerance
- C. Proxy servers
- D. Replication

Answer: A

530. An administrator discovers that some files on a database server were recently encrypted. The administrator sees from the security logs that the data was last accessed by a domain user. Which of the following best describes the type of attack that occurred?

- A. Insider threat
- B. Social engineering
- C. Watering-hole
- D. Unauthorized attacker

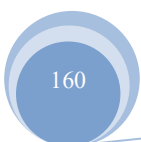
Answer: A

531. A security analyst receives an alert that there was an attempt to download known malware. Which of the following actions would allow the best chance to analyze the malware?

- A. Review the IPS logs and determine which command-and-control IPs were blocked.
- B. Analyze application logs to see how the malware attempted to maintain persistence.
- C. Run vulnerability scans to check for systems and applications that are vulnerable to the malware.
- D. Obtain and execute the malware in a sandbox environment and perform packet captures.

Answer: D

532. The analyst wants to move data from production to the UAT server for testing the latest release. Which





of the following strategies to protect data should the analyst use?

- A. Data masking
- B. Data tokenization
- C. Data obfuscation
- D. Data encryption

Answer: A

533. A recent penetration test identified that an attacker could flood the MAC address table of network switches. Which of the following would best mitigate this type of attack?

- A. Load balancer
- B. Port security
- C. IPS
- D. NGFW

Answer: B

534. A company recently decided to allow employees to work remotely. The company wants to protect its data without using a VPN. Which of the following technologies should the company implement?

- A. Secure web gateway
- B. Virtual private cloud endpoint
- C. Deep packet inspection
- D. Next-generation firewall

Answer: A

535. A security analyst is investigating a workstation that is suspected of outbound communication to a command-and-control server. During the investigation, the analyst discovered that logs on the endpoint were deleted. Which of the following logs would the analyst most likely look at next?

- A. IPS
- B. Firewall
- C. ACL
- D. Windows security



Answer: B

536. A company is developing a business continuity strategy and needs to determine how many staff members would be required to sustain the business in the case of a disruption. Which of the following best describes this step?

- A. Capacity planning
- B. Redundancy
- C. Geographic dispersion
- D. Tablet exercise

Answer: A

537. Which of the following would best explain why a security analyst is running daily vulnerability scans on all corporate endpoints?

- A. To track the status of patching installations
- B. To find shadow IT cloud deployments
- C. To continuously the monitor hardware inventory
- D. To hunt for active attackers in the network

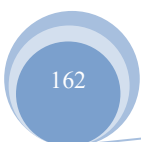
Answer: A

538. Which of the following would most likely be deployed to obtain and analyze attacker activity and techniques?

- A. Firewall
- B. IDS
- C. Honeypot
- D. Layer 3 switch

Answer: C

539. A company relies on open-source software libraries to build the software used by its customers. Which of the following vulnerability types would be the most difficult to remediate due to the company's reliance on open-source libraries?





- A. Buffer overflow
- B. SQL injection
- C. Cross-site scripting
- D. Zero day

Answer: D

540. Which of the following is the best way to prevent an unauthorized user from plugging a laptop into an employee's phone network port and then using tools to scan for database servers?

- A. MAC filtering
- B. Segmentation
- C. Certification
- D. Isolation

Answer: A

541. A security analyst locates a potentially malicious video file on a server and needs to identify both the creation date and the file's creator. Which of the following actions would most likely give the security analyst the information required?

- A. Obtain the file's SHA-256 hash.
- B. Use hexdump on the file's contents.
- C. Check endpoint logs.
- D. Query the file's metadata.

Answer: D

542. After completing an annual external penetration test, a company receives the following guidance:

- ☞ Decommission two unused web servers currently exposed to the internet.
- ☞ Close 18 open and unused ports found on their existing production web servers.
- ☞ Remove company email addresses and contact info from public domain registration records.

Which of the following does this represent?

- A. Attack surface reduction
- B. Vulnerability assessment



- C. Tabletop exercise
- D. Business impact analysis

Answer: A

543. Which of the following security controls are a company implementing by deploying HIPS? (Select two).

- A. Directive
- B. Preventive
- C. Physical
- D. Corrective
- E. Compensating
- F. Detective

Answer: B,F

544. A security team is setting up a new environment for hosting the organization's on-premises software application as a cloud-based service. Which of the following should the team ensure is in place in order for the organization to follow security best practices?

- A. Visualization and isolation of resources
- B. Network segmentation
- C. Data encryption
- D. Strong authentication policies

Answer: A

545. An administrator is estimating the cost associated with an attack that could result in the replacement of a physical server. Which of the following processes is the administrator performing?

- A. Quantitative risk analysis
- B. Disaster recovery test
- C. Physical security controls review
- D. Threat modeling

Answer: A



546. During a recent log review, an analyst discovers evidence of successful injection attacks. Which of the following will best address this issue?

- A. Authentication
- B. Secure cookies
- C. Static code analysis
- D. Input validation

Answer: D

547. Which of the following digital forensics activities would a security team perform when responding to legal requests in a pending investigation?

- A. E-discovery
- B. User provisioning
- C. Firewall log export
- D. Root cause analysis

Answer: A

548. A company discovered its data was advertised for sale on the dark web. During the initial investigation, the company determined the data was proprietary data. Which of the following is the next step the company should take?

- A. Identify the attacker sentry methods.
- B. Report the breach to the local authorities.
- C. Notify the applicable parties of the breach.
- D. Implement vulnerability scanning of the company's systems.

Answer: C

549. Which of the following steps in the risk management process involves establishing the scope and potential risks involved with a project?

- A. Risk mitigation
- B. Risk identification
- C. Risk treatment



D. Risk monitoring and review

Answer: B

550. Which of the following roles, according to the shared responsibility model, is responsible for securing the company's database in an IaaS model for a cloud environment?

- A. Client
- B. Third-party vendor
- C. Cloud provider
- D. DBA

Answer: A

551. A security administrator would like to protect data on employees' laptops. Which of the following encryption techniques should the security administrator use?

- A. Partition
- B. Asymmetric
- C. Full disk
- D. Database

Answer: C

552. Which of the following architectures is most suitable to provide redundancy for critical business processes?

- A. Network-enabled
- B. Server-side
- C. Cloud-native
- D. Multitenant

Answer: C

553. SIMULATION

A recent black-box penetration test of <http://example.com> discovered that external website vulnerabilities exist, such as directory traversals, cross-site scripting, cross-site forgery, and insecure protocols.

You are tasked with reducing the attack space and enabling secure protocols. INSTRUCTIONS

Part 1

Use the drop-down menus to select the appropriate technologies for each location to implement a secure and resilient web architecture. Not all technologies will be used, and technologies may be used multiple times.

Part 2

Use the drop-down menus to select the appropriate command snippets from the drop-down menus. Each command section must be filled.

Part 1

Part 2

The diagram shows a network architecture with three main zones: Internet, DMZ, and Internal Network. Each zone has a 'Select' dropdown menu for technology selection. The Internet zone is represented by a cloud icon. The DMZ zone is represented by a box with a 'Select' dropdown. The Internal Network zone is represented by a box with a 'Select' dropdown. Arrows indicate traffic flow between these zones.

Part 1: Technology Selection

Available technologies for selection:

- Switch
- Router
- Web server
- PKI certificate
- WAF
- Firewall

Part 2: Command Snippet Selection

Available command snippets for selection:

- Switch
- Router
- Web server
- PKI certificate
- WAF
- Firewall

Part 1 Part 2

```
openssl req -new -newkey Select command \
-key /certificate/csr.key -out Select command
Generating RSA private key, Select command
.....+++
-----+++
e is 65537 (0x10001)
```

Part 1 Part 2

```
openssl req -new -newkey Select command \
1024 bit long modulus
/certificate/example.com.crt
/certificate/example.com.p7b
rsa:2048
rsa:1024
/certificate/example.com.pem
2048 bit long modulus
/certificate/example.com.csr
-key /certificate/csr.key -out Select command
1024 bit long modulus
/certificate/example.com.crt
/certificate/example.com.p7b
rsa:2048
rsa:1024
/certificate/example.com.pem
2048 bit long modulus
/certificate/example.com.csr
Generating RSA private key, Select command
1024 bit long modulus
/certificate/example.com.crt
/certificate/example.com.p7b
rsa:2048
rsa:1024
/certificate/example.com.pem
2048 bit long modulus
/certificate/example.com.csr
.....+++
-----+++
e is 65537 (0x10001)
```

Answer:

See the solution in explanation below.

Explanation:

MISSING

554. A software developer would like to ensure. The source code cannot be reverse engineered or



debugged. Which of the following should the developer consider?

- A. Version control
- B. Obfuscation toolkit
- C. Code reuse
- D. Continuous integration
- E. Stored procedures

Answer: B

555. An administrator has identified and fingerprinted specific files that will generate an alert if an attempt is made to email these files outside of the organization. Which of the following best describes the tool the administrator is using?

- A. DLP
- B. SNMP traps
- C. SCAP
- D. IPS

Answer: A

556. A security administrator is reissuing a former employee's laptop. Which of the following is the best combination of data handling activities for the administrator to perform? (Select two).

- A. Data retention
- B. Certification
- C. Tokenization
- D. Classification
- E. Sanitization
- F. Enumeration

Answer: C,E

557. Executives at a company are concerned about employees accessing systems and information about sensitive company projects unrelated to the employees' normal job duties. Which of the following enterprise security capabilities will the security team most likely deploy to detect that activity?



- A. UBA
- B. EDR
- C. NAC
- D. DLP

Answer: A

558. A security consultant is working with a client that wants to physically isolate its secure systems. Which of the following best describes this architecture?

- A. SDN
- B. Air gapped
- C. Containerized
- D. Highly available

Answer: B

559. A company is concerned about the theft of client data from decommissioned laptops. Which of the following is the most cost-effective method to decrease this risk?

- A. Wiping
- B. Recycling
- C. Shredding
- D. Deletion

Answer: A

560. Which of the following would most likely be used by attackers to perform credential harvesting?

- A. Social engineering
- B. Supply chain compromise
- C. Third-party software
- D. Rainbow table

Answer: A



561. While investigating a recent security breach an analyst finds that an attacker gained access by SQL injection through a company website. Which of the following should the analyst recommend to the website developers to prevent this from reoccurring?

- A. Secure cookies
- B. Input sanitization
- C. Code signing
- D. Blocklist

Answer: B

562. Which of the following describes the difference between encryption and hashing?

- A. Encryption protects data in transit, while hashing protects data at rest.
- B. Encryption replaces cleartext with ciphertext, while hashing calculates a checksum.
- C. Encryption ensures data integrity, while hashing ensures data confidentiality.
- D. Encryption uses a public-key exchange, while hashing uses a private key.

Answer: B

563. An enterprise has been experiencing attacks focused on exploiting vulnerabilities in older browser versions with well-known exploits. Which of the following security solutions should be configured to best provide the ability to monitor and block these known signature-based attacks?

- A. ACL
- B. DLP
- C. IDS
- D. IPS

Answer: D

564. A hacker gained access to a system via a phishing attempt that was a direct result of a user clicking a suspicious link. The link laterally deployed ransomware, which laid dormant for multiple weeks, across the network. Which of the following would have mitigated the spread?

- A. IPS
- B. IDS



C. WAF

D. UAT

Answer: A

565. An administrator at a small business notices an increase in support calls from employees who receive a blocked page message after trying to navigate to a spoofed website. Which of the following should the administrator do?

A. Deploy multifactor authentication.

B. Decrease the level of the web filter settings

C. Implement security awareness training.

D. Update the acceptable use policy

Answer: C

566. Two companies are in the process of merging. The companies need to decide how to standardize their information security programs. Which of the following would best align the security programs?

A. Shared deployment of CIS baselines

B. Joint cybersecurity best practices

C. Both companies following the same CSF

D. Assessment of controls in a vulnerability report

Answer: C

567. The internal audit team determines a software application is no longer in scope for external reporting requirements. Which of the following will confirm management's perspective that the application is no longer applicable?

A. Data inventory and retention

B. Right to be forgotten

C. Due care and due diligence

D. Acknowledgement and attestation

Answer: D



568. Employees sign an agreement that restricts specific activities when leaving the company. Violating the agreement can result in legal consequences. Which of the following agreements does this best describe?

- A. SLA
- B. BPA
- C. NDA
- D. MOA

Answer: C

569. In which of the following scenarios is tokenization the best privacy technique to use?

- A. Providing pseudo-anonymization for social media user accounts
- B. Serving as a second factor for authentication requests
- C. Enabling established customers to safely store credit card information
- D. Masking personal information inside databases by segmenting data

Answer: C

570. Which of the following control types describes an alert from a SIEM tool?

- A. Preventive
- B. Corrective
- C. Compensating
- D. Detective

Answer: D

571. Which of the following best explains a concern with OS-based vulnerabilities?

- A. An exploit would give an attacker access to system functions that span multiple applications.
- B. The OS vendor's patch cycle is not frequent enough to mitigate the large number of threats.
- C. Most users trust the core operating system features and may not notice if the system has been compromised.
- D. Exploitation of an operating system vulnerability is typically easier than any other vulnerability.

Answer: A



572. Which of the following data types best describes an AI tool developed by a company to automate the ticketing system under a specific contract?

- A. Classified
- B. Regulated information
- C. Open source
- D. Intellectual property

Answer: D

573. An MSSP manages firewalls for hundreds of clients. Which of the following tools would be most helpful to create a standard configuration template in order to improve the efficiency of firewall changes?

- A. SNMP
- B. Benchmarks
- C. Netflow
- D. SCAP

Answer: B

574. Which of the following is a feature of a next-generation SIEM system?

- A. Virus signatures
- B. Automated response actions
- C. Security agent deployment
- D. Vulnerability scanning

Answer: B

575. A security analyst developed a script to automate a trivial and repeatable task. Which of the following best describes the benefits of ensuring other team members understand how the script works?

- A. To reduce implementation cost
- B. To identify complexity
- C. To remediate technical debt
- D. To prevent a single point of failure

Answer: D



576. A company is redesigning its infrastructure and wants to reduce the number of physical servers in use. Which of the following architectures is best suited for this goal?

- A. Isolation
- B. Segmentation
- C. Virtualization
- D. Redundancy

Answer: C

577. A security administrator needs to reduce the attack surface in the company's data centers. Which of the following should the security administrator do to complete this task?

- A. Implement a honeynet.
- B. Define Group Policy on the servers.
- C. Configure the servers for high availability.
- D. Upgrade end-of-support operating systems.

Answer: D

578. The security team at a large global company needs to reduce the cost of storing data used for performing investigations. Which of the following types of data should have its retention length reduced?

- A. Packet capture
- B. Endpoint logs
- C. OS security logs
- D. Vulnerability scan

Answer: A

579. A systems administrator needs to provide traveling employees with a tool that will protect company devices regardless of where they are working. Which of the following should the administrator implement?

- A. Isolation
- B. Segmentation
- C. ACL



D. HIPS

Answer: D

580. A security analyst is creating base for the server team to follow when hardening new devices for deployment. Which of the following best describes what the analyst is creating?

- A. Change management procedure
- B. Information security policy
- C. Cybersecurity framework
- D. Secure configuration guide

Answer: D

581. At the start of a penetration test, the tester checks OSINT resources for information about the client environment. Which of the following types of reconnaissance is the tester performing?

- A. Active
- B. Passive
- C. Offensive
- D. Defensive

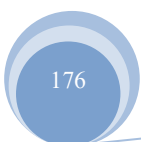
Answer: B

582. A company's web filter is configured to scan the URL for strings and deny access when matches are found. Which of the following search strings should an analyst employ to prohibit access to non-encrypted websites?

- A. encryption=off\
- B. http://
- C. www.*.com
- D. :443

Answer: B

583. An organization wants to improve the company's security authentication method for remote employees. Given the following requirements:





- Must work across SaaS and internal network applications
- Must be device manufacturer agnostic
- Must have offline capabilities

Which of the following would be the most appropriate authentication method?

- A. Username and password
- B. Biometrics
- C. SMS verification
- D. Time-based tokens

Answer: D

584. In which of the following will unencrypted PLC management traffic most likely be found?

- A. SDN
- B. IoT
- C. VPN
- D. SCADA

Answer: D

585. A security analyst is reviewing logs and discovers the following:

```
149.34.228.10 - - [28/Jun/2023:16:32:45 -0300] "GET / HTTP/1.0" User-Agent: 6[/bin/sh/ id] 200 397
```

Which of the following should be used to best mitigate this type of attack?

- A. Input sanitization
- B. Secure cookies
- C. Static code analysis
- D. Sandboxing

Answer: A

586. Which of the following should an organization focus on the most when making decisions about vulnerability prioritization?

- A. Exposure factor
- B. CVSS



- C. CVE
- D. Industry impact

Answer: B

587. A systems administrator needs to ensure the secure communication of sensitive data within the organization's private cloud. Which of the following is the best choice for the administrator to implement?

- A. IPSec
- B. SHA-1
- C. RSA
- D. TGT

Answer: A

588. The management team notices that new accounts that are set up manually do not always have correct access or permissions.

Which of the following automation techniques should a systems administrator use to streamline account creation?

- A. Guard rail script
- B. Ticketing workflow
- C. Escalation script
- D. User provisioning script

Answer: D

589. Which of the following attacks primarily targets insecure networks?

- A. Evil twin
- B. Impersonation
- C. Watering hole
- D. Pretexting

Answer: A

590. Which of the following should be deployed on an externally facing web server in order to establish an



encrypted connection?

- A. Public key
- B. Private Key
- C. Asymmetric key
- D. Symmetric key

Answer: A

591. Which of the following would be best suited for constantly changing environments?

- A. RTOS
- B. Containers
- C. Embedded systems
- D. SCADA

Answer: B

592. Which of the following should an organization use to protect its environment from external attacks conducted by an unauthorized hacker?

- A. ACL
- B. IDS
- C. HIDS
- D. NIPS

Answer: B

593. An attacker posing as the Chief Executive Officer calls an employee and instructs the employee to buy gift cards. Which of the following techniques is the attacker using?

- A. Smishing
- B. Disinformation
- C. Impersonating
- D. Whaling

Answer: D



594. Which of the following would best allow a company to prevent access to systems from the Internet?

- A. Containerization
- B. Virtualization
- C. SD-WAN
- D. Air-gapped

Answer: D

595. A security analyst finds a rogue device during a monthly audit of current endpoint assets that are connected to the network. The corporate network utilizes 002.1X for access control. To be allowed on the network, a device must have a Known hardware address, and a valid user name and password must be entered in a captive portal. The following is the audit report:

IP address	MAC	Host	Account
10.18.04.42	BE-AC-11-F1-E4-44	PC-NY	user1
10.18.04.38	EB-AC-11-82-42-F3	PC-CA	user3
10.18.04.59	28-BB-5A-11-52-29	PC-PA	user2
10.18.04.58	28-BB-5A-F0-E9-D1	PC-TX	user4
10.18.04.22	EB-AC-11-82-42-F3	WIN10	user3
10.18.04.26	BB-28-11-21-A2-73	PC-NJ	admin

Which of the following is the most likely way a rogue device was allowed to connect?

- A. A user performed a MAC cloning attack with a personal device.
- B. A DMCP failure caused an incorrect IP address to be distributed
- C. An administrator bypassed the security controls for testing.
- D. DNS hijacking let an attacker intercept the captive portal traffic.

Answer: A

596. Which of the following is prevented by proper data sanitization?

- A. Hackers' ability to obtain data from used hard drives
- B. Devices reaching end-of-life and losing support
- C. Disclosure of sensitive data through incorrect classification
- D. Incorrect inventory data leading to a laptop shortage

Answer: A

597. A systems administrator notices that one of the systems critical for processing customer transactions



is running an end-of-life operating system. Which of the following techniques would increase enterprise security?

- A. Installing HIDS on the system
- B. Placing the system in an isolated VLAN
- C. Decommissioning the system
- D. Encrypting the system's hard drive

Answer: B

598. Which of the following are the best security controls for controlling on-premises access? (Select two.)

- A. Swipe card
- B. Picture ID
- C. Phone authentication application
- D. Biometric scanner
- E. Camera
- F. Memorable

Answer: A,D

599. An enterprise is trying to limit outbound DNS traffic originating from its internal network. Outbound DNS requests will only be allowed from one device with the IP address 10.50.10.25. Which of the following firewall ACLs will accomplish this goal?

- A. Access list outbound permit 0.0.0.0/0 0.0.0.0/0 port 53Access list outbound deny 10.50.10.25/32 0.0.0.0/0 port 53
- B. Access list outbound permit 0.0.0.0/0 10.50.10.25/32 port 53Access list outbound deny 0.0.0.0/0 0.0.0.0/0 port 53
- C. Access list outbound permit 0.0.0.0/0 0.0.0.0/0 port 53Access list outbound deny 0.0.0.0/0 10.50.10.25/32 port 53
- D. Access list outbound permit 10.50.10.25/32 0.0.0.0/0 port 53Access list outbound deny 0.0.0.0/0 0.0.0.0/0 port 53

Answer: D



600. An organization recently updated its security policy to include the following statement:

Regular expressions are included in source code to remove special characters such as \$, |, ;, &, `, and ? from variables set by forms in a web application.

Which of the following best explains the security technique the organization adopted by making this addition to the policy?

- A. Identify embedded keys
- B. Code debugging
- C. Input validation
- D. Static code analysis

Answer: C

601. Which of the following definitions best describes the concept of log co-relation?

- A. Combining relevant logs from multiple sources into one location
- B. Searching and processing data to identify patterns of malicious activity
- C. Making a record of the events that occur in the system
- D. Analyzing the log files of the system components

Answer: D

602. A security analyst is reviewing the following logs:

```
[10:00:00 AM] Login rejected - username administrator - password Spring2023
[10:00:01 AM] Login rejected - username jsmith - password Spring2023
[10:00:01 AM] Login rejected - username guest - password Spring2023
[10:00:02 AM] Login rejected - username cpolk - password Spring2023
[10:00:03 AM] Login rejected - username fmartin - password Spring2023
```

Which of the following attacks is most likely occurring?

- A. Password spraying
- B. Account forgery
- C. Pass-the-hash
- D. Brute-force

Answer: A

603. A customer of a large company receives a phone call from someone claiming to work for the company





and asking for the customer's credit card information. The customer sees the caller ID is the same as the company's main phone number. Which of the following attacks is the customer most likely a target of?

- A. Phishing
- B. Whaling
- C. Smishing
- D. Vishing

Answer: D

604. Which of the following is the most likely to be used to document risks, responsible parties, and thresholds?

- A. Risk tolerance
- B. Risk transfer
- C. Risk register
- D. Risk analysis

Answer: C

605. A network manager wants to protect the company's VPN by implementing multifactor authentication that uses:

- . Something you know
- . Something you have
- . Something you are

Which of the following would accomplish the manager's goal?

- A. Domain name, PKI, GeolIP lookup
- B. VPN IP address, company ID, facial structure
- C. Password, authentication token, thumbprint
- D. Company URL, TLS certificate, home address

Answer: C

606. Which of the following technologies assists in passively verifying the expired status of a digital certificate?



- A. OCSP
- B. CRL
- C. TPM
- D. CSR

Answer: A

607. A vendor needs to remotely and securely transfer files from one server to another using the command line. Which of the following protocols should be implemented to allow for this type of access? (Select two).

- A. SSH
- B. SNMP
- C. RDP
- D. S/MIME
- E. SMTP
- F. SFTP

Answer: A,F

608. An organization is evaluating new regulatory requirements associated with the implementation of corrective controls on a group of interconnected financial systems. Which of the following is the most likely reason for the new requirement?

- A. To defend against insider threats altering banking details
- B. To ensure that errors are not passed to other systems
- C. To allow for business insurance to be purchased
- D. To prevent unauthorized changes to financial data

Answer: B

609. The physical security team at a company receives reports that employees are not displaying their badges. The team also observes employees tailgating at controlled entrances. Which of the following topics will the security team most likely emphasize in upcoming security training?

- A. Social engineering
- B. Situational awareness



- C. Phishing
- D. Acceptable use policy

Answer: B

610. An organization's web servers host an online ordering system. The organization discovers that the servers are vulnerable to a malicious JavaScript injection, which could allow attackers to access customer payment information. Which of the following mitigation strategies would be most effective for preventing an attack on the organization's web servers? (Select two).

- A. Regularly updating server software and patches
- B. Implementing strong password policies
- C. Encrypting sensitive data at rest and in transit
- D. Utilizing a web-application firewall
- E. Performing regular vulnerability scans
- F. Removing payment information from the servers

Answer: A,D

611. A security administrator receives multiple reports about the same suspicious email. Which of the following is the most likely reason for the malicious email's continued delivery?

- A. Employees are flagging legitimate emails as spam.
- B. Information from reported emails is not being used to tune email filtering tools.
- C. Employees are using shadow IT solutions for email.
- D. Employees are forwarding personal emails to company email addresses.

Answer: B

612. A company wants to verify that the software the company is deploying came from the vendor the company purchased the software from. Which of the following is the best way for the company to confirm this information?

- A. Validate the code signature.
- B. Execute the code in a sandbox.
- C. Search the executable for ASCII strings.



D. Generate a hash of the files.

Answer: A

613. A company is required to use certified hardware when building networks. Which of the following best addresses the risks associated with procuring counterfeit hardware?

- A. A thorough analysis of the supply chain
- B. A legally enforceable corporate acquisition policy
- C. A right to audit clause in vendor contracts and SOWs
- D. An in-depth penetration test of all suppliers and vendors

Answer: A

614. Which of the following would be the greatest concern for a company that is aware of the consequences of non-compliance with government regulations?

- A. Right to be forgotten
- B. Sanctions
- C. External compliance reporting
- D. Attestation

Answer: B

615. The local administrator account for a company's VPN appliance was unexpectedly used to log in to the remote management interface. Which of the following would have most likely prevented this from happening'?

- A. Using least privilege
- B. Changing the default password
- C. Assigning individual user IDs
- D. Reviewing logs more frequently

Answer: B

616. An analyst identifies that multiple users have the same passwords, but the hashes appear to be completely different. Which of the following most likely explains this issue?



- A. Data masking
- B. Salting
- C. Key escrow
- D. Tokenization

Answer: B

617. A company's marketing department collects, modifies, and stores sensitive customer data. The infrastructure team is responsible for securing the data while in transit and at rest. Which of the following data roles describes the customer?

- A. Processor
- B. Custodian
- C. Subject
- D. Owner

Answer: C

618. A penetration test identifies that an SMBv1 is enabled on multiple servers across an organization. The organization wants to remediate this vulnerability in the most efficient way possible. Which of the following should the organization use for this purpose?

- A. GPO
- B. ACL
- C. SFTP
- D. DLP

Answer: A

619. An accountant is transferring information to a bank over FTP. Which of the following mitigations should the accountant use to protect the confidentiality of the data?

- A. Tokenization
- B. Data masking
- C. Encryption
- D. Obfuscation



Answer: C

620. While a school district is performing state testing, a security analyst notices all internet services are unavailable. The analyst discovers that ARP poisoning is occurring on the network and then terminates access for the host. Which of the following is most likely responsible for this malicious activity?

- A. Unskilled attacker
- B. Shadow IT
- C. Credential stuffing
- D. DMARC failure

Answer: A

621. An organization wants to donate its aging network hardware. Which of the following should the organization perform to prevent any network details from leaking?

- A. Destruction
- B. Sanitization
- C. Certification
- D. Data retention

Answer: B

622. Which of the following should an internal auditor check for first when conducting an audit of the organization's risk management program?

- A. Policies and procedures
- B. Asset management
- C. Vulnerability assessment
- D. Business impact analysts

Answer: A

623. Which of the following should a systems administrator use to ensure an easy deployment of resources within the cloud provider?

- A. Software as a service



- B. Infrastructure as code
- C. Internet of Things
- D. Software-defined networking

Answer: B

624. Which of the following must be considered when designing a high-availability network? (Choose two).

- A. Ease of recovery
- B. Ability to patch
- C. Physical isolation
- D. Responsiveness
- E. Attack surface
- F. Extensible authentication

Answer: A,E

625. A systems administrator set up a perimeter firewall but continues to notice suspicious connections between internal endpoints. Which of the following should be set up in order to mitigate the threat posed by the suspicious activity?

- A. Host-based firewall
- B. Web application firewall
- C. Access control list
- D. Application allow list

Answer: A

626. Which of the following most accurately describes the order in which a security engineer should implement secure baselines?

- A. Deploy, maintain, establish
- B. Establish, maintain, deploy
- C. Establish, deploy, maintain
- D. Deploy, establish, maintain

Answer: C



627. A client demands at least 99.99% uptime from a service provider's hosted security services. Which of the following documents includes the information the service provider should return to the client?

- A. MOA
- B. SOW
- C. MOU
- D. SLA

Answer: D

628. A security officer observes that a software development team is not complying with its corporate security policy on encrypting confidential data. Which of the following categories refers to this type of non-compliance?

- A. External
- B. Standard
- C. Regulation
- D. Internal

Answer: D

629. A security administrator is addressing an issue with a legacy system that communicates data using an unencrypted protocol to transfer sensitive data to a third party. No software updates that use an encrypted protocol are available, so a compensating control is needed. Which of the following are the most appropriate for the administrator to suggest? (Select two.)

- A. Tokenization
- B. Cryptographic downgrade
- C. SSH tunneling
- D. Segmentation
- E. Patch installation
- F. Data masking

Answer: C,D



630. A service provider wants a cost-effective way to rapidly expand from providing internet links to managing them. Which of the following methods will allow the service provider to best scale its services while maintaining performance consistency?

- A. Escalation support
- B. Increased workforce
- C. Baseline enforcement
- D. Technical debt

Answer: C

631. Which of the following tasks is typically included in the BIA process?

- A. Estimating the recovery time of systems
- B. Identifying the communication strategy
- C. Evaluating the risk management plan
- D. Establishing the backup and recovery procedures
- E. Developing the incident response plan

Answer: A

632. Which of the following has been implemented when a host-based firewall on a legacy Linux system allows connections from only specific internal IP addresses?

- A. Compensating control
- B. Network segmentation
- C. Transfer of risk
- D. SNMP traps

Answer: A

633. A security engineer would like to enhance the use of automation and orchestration within the SIEM. Which of the following would be the primary benefit of this enhancement?

- A. It increases complexity.
- B. It removes technical debt.
- C. It adds additional guard rails.



D. It acts as a workforce multiplier.

Answer: D

634. A security analyst is assessing several company firewalls. Which of the following tools would the analyst most likely use to generate custom packets to use during the assessment?

- A. hping
- B. Wireshark
- C. PowerShell
- D. netstat

Answer: A

635. Which of the following is a benefit of vendor diversity?

- A. Patch availability
- B. Zero-day resiliency
- C. Secure configuration guide applicability
- D. Load balancing

Answer: B

636. Which of the following actions would reduce the number of false positives for an analyst to manually review?

- A. Create playbooks as part of a SOAR platform
- B. Redefine the patch management process
- C. Replace an EDR tool with an XDR solution
- D. Disable AV heuristics scanning

Answer: A

637. Which of the following considerations is the most important for an organization to evaluate as it establishes and maintains a data privacy program?

- A. Reporting structure for the data privacy officer
- B. Request process for data subject access



- C. Role as controller or processor
- D. Physical location of the company

Answer: C

638. A security practitioner completes a vulnerability assessment on a company's network and finds several vulnerabilities, which the operations team remediates. Which of the following should be done next?

- A. Conduct an audit.
- B. Initiate a penetration test.
- C. Rescan the network.
- D. Submit a report.

Answer: C

639. A certificate authority needs to post information about expired certificates. Which of the following would accomplish this task?

- A. TPM
- B. CRL
- C. PKI
- D. CSR

Answer: B

640. Since a recent upgrade of a WLAN infrastructure, several mobile users have been unable to access the internet from the lobby. The networking team performs a heat map survey of the building and finds several WAPs in the area. The WAPs are using similar frequencies with high power settings. Which of the following installation considerations should the security team evaluate next?

- A. Channel overlap
- B. Encryption type
- C. New WLAN deployment
- D. WAP placement

Answer: A

641. A Chief Security Officer signs off on a request to allow inbound SMB and RDP from the internet to a single VLAN. Which of the following is the most likely explanation for this activity?

- A. The company built a new file-sharing site.
- B. The organization is preparing for a penetration test.
- C. The security team is integrating with an SASE platform.
- D. The security team created a honeynet.

Answer: D

642. Which of the following data types relates to data sovereignty?

- A. Data classified as public in other countries
- B. Personally Identifiable data while traveling
- C. Health data shared between doctors in other nations
- D. Data at rest outside of a country's borders

Answer: D